

Advance Security Features

Objective

- ❖ Focus: Security Hub, IAM, SCPs, Permission Boundaries, Config, CloudTrail, GuardDuty
- ❖ Build secure multi-account posture with AWS native tools
- ❖ Learn integration patterns and automation for scale
- ❖ Emphasis on least privilege and continuous compliance
- ❖ Hands-on mindset: from alerts to actionable remediation

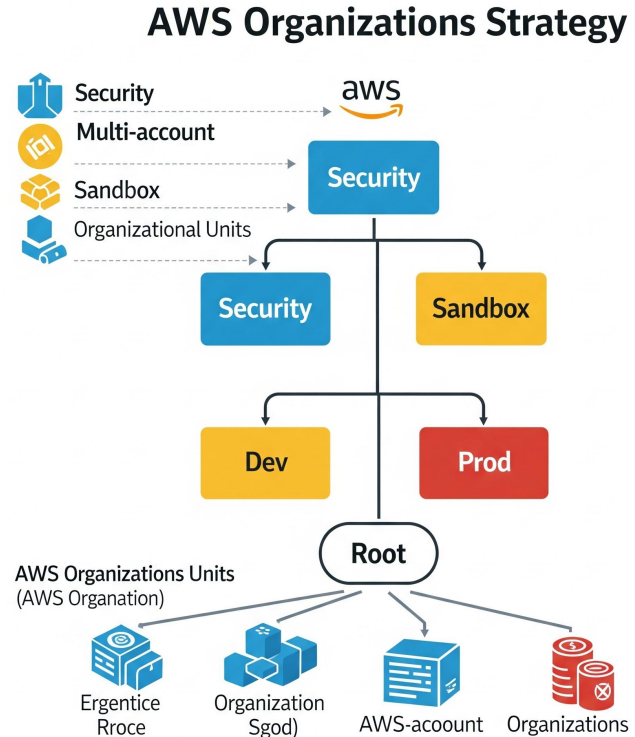
Shared Responsibility in Practice

- ❖ AWS secures the cloud; you secure in the cloud
- ❖ Service models change your controls (IaaS vs PaaS vs SaaS)
- ❖ Map controls to CIS/NIST/ISO requirements
- ❖ Identify data classification & regulatory constraints early
- ❖ Align people/process/tools to your control objectives



Multi-Account Strategy with Organizations

- ❖ Use AWS Organizations to segment risk & blast radius
- ❖ Core OUs: Security, Sandbox, Dev, Prod
- ❖ Centralize logging & security tooling in Security OU
- ❖ Route findings to aggregator in delegated admin accounts
- ❖ Govern with SCPs at OU boundaries



Identity-Driven Defense

- ❖ Identity is the new perimeter (API-driven cloud)
- ❖ Minimize long-lived credentials; prefer assume-role
- ❖ Enforce MFA for human & break-glass access
- ❖ Use permission boundaries for builders at scale
- ❖ Continuously validate access with IAM Access Analyzer
- ❖



Data-Centric Security

- ❖ Encrypt at rest (KMS) and in transit (TLS) by default
- ❖ Separate key admins from data admins
- ❖ Tag data resources for ownership & retention policies
- ❖ Monitor access patterns with CloudTrail Lake/CloudWatch
- ❖ Alert on policy drift & public access misconfigurations



AWS Security Hub Deep Dive

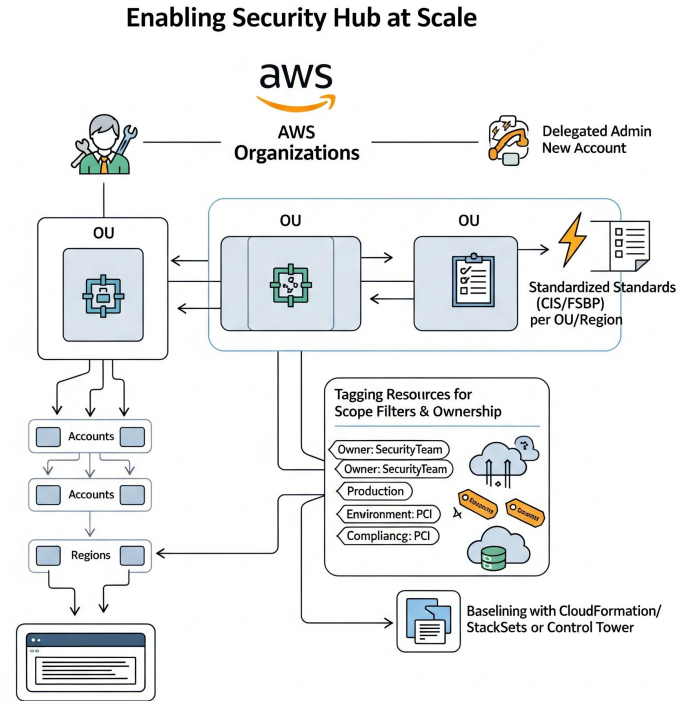
Security Hub Overview

- ❖ Central findings aggregator across AWS accounts/regions
- ❖ Normalizes via AWS Security Finding Format (ASFF)
- ❖ Integrates with GuardDuty, Config, Inspector, Macie, etc.
- ❖ Benchmarks: CIS AWS Foundations, Foundational Security
- ❖ Single pane for prioritization and compliance status



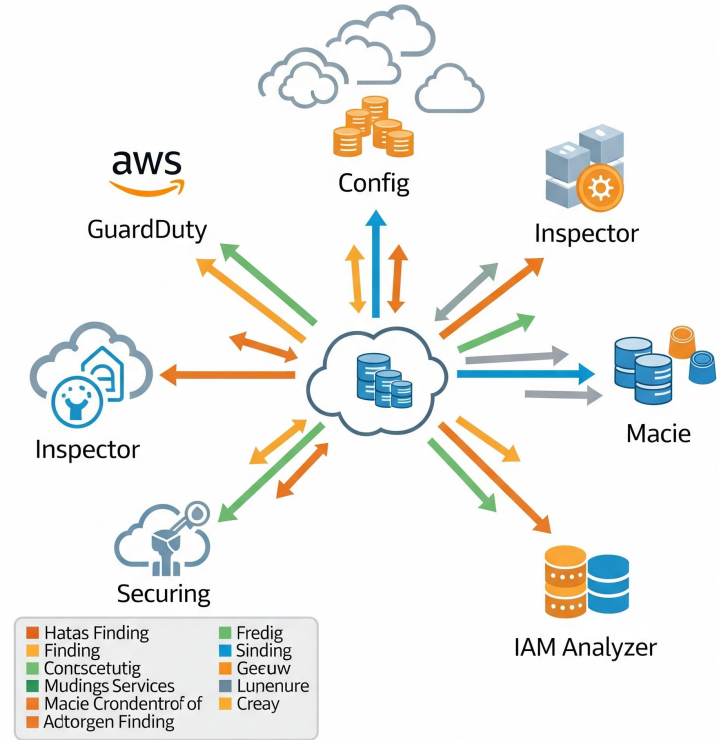
Enabling Security Hub at Scale

- ❖ Use Organizations delegated admin to centrally enable
- ❖ Auto-enable new accounts via Security Hub settings
- ❖ Standardize standards (CIS/FSBP) per OU/region
- ❖ Tag resources to drive scope filters & ownership
- ❖ Baseline with CloudFormation/StackSets or Control Tower



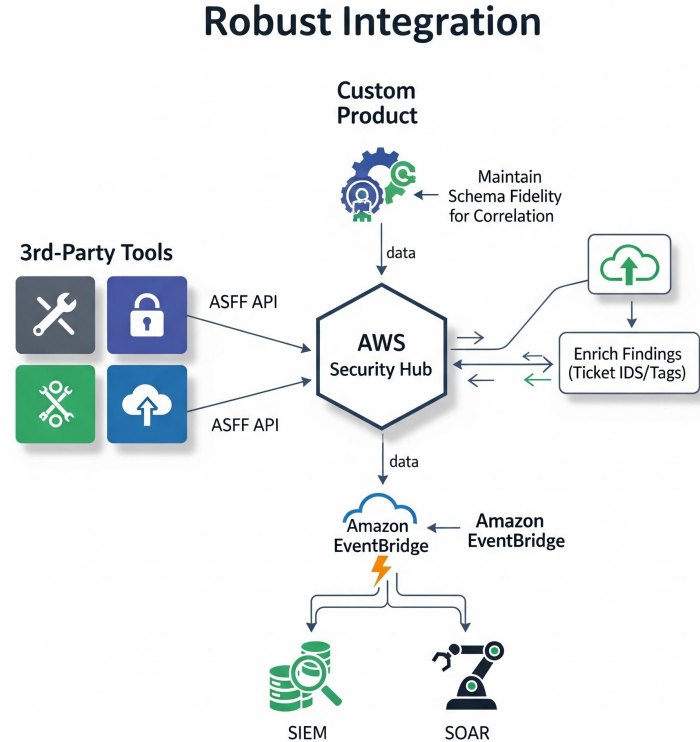
Integrations — Native AWS

- ❖ **GuardDuty** → threat detections flow into findings
- ❖ **Config** → rule non-compliance mapped as findings
- ❖ **Inspector** → vulnerability & package CVE findings
- ❖ **Macie** → sensitive data discovery alerts
- ❖ **IAM Analyzer** → external access findings (via integrations)



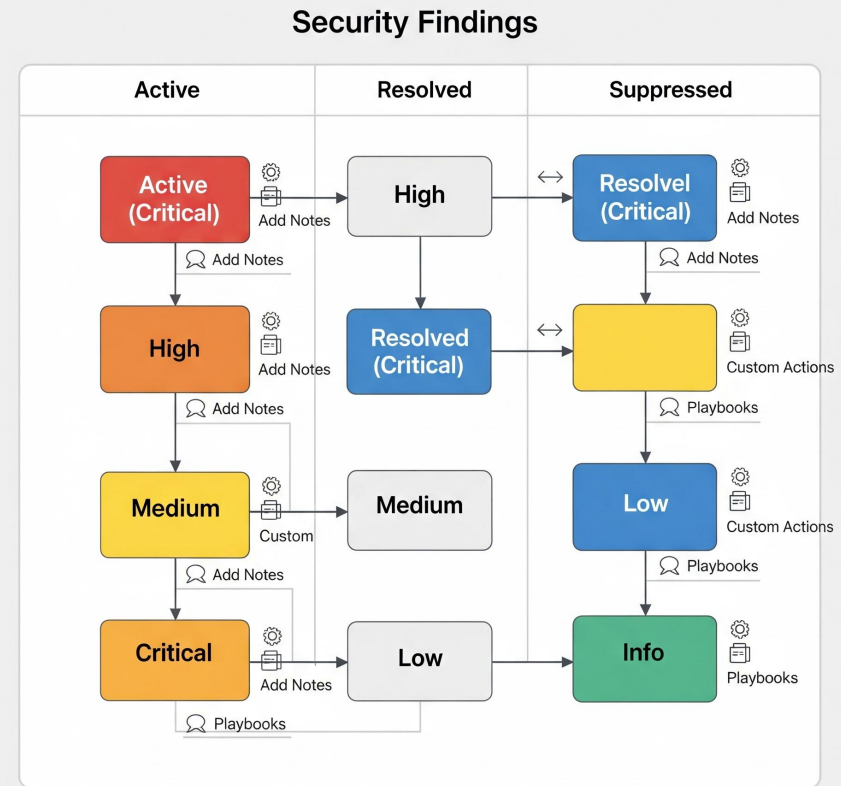
Integrations — Partner & Custom

- ❖ 3rd-party tools push to Security Hub via **ASFF API**
- ❖ Enrich findings with **ticket IDs/tags** (bi-directional sync)
- ❖ **EventBridge** routes findings to SIEM/SOAR
- ❖ Use **custom product** to ingest internal scanner results
- ❖ Maintain **schema fidelity** for correlation downstream



Findings Lifecycle

- ❖ States: Active → Resolved → Suppressed
- ❖ Severity normalization: Critical/High/Medium/Low/Info
- ❖ Use workflow status & record state consistently
- ❖ Add notes & related findings to preserve context
- ❖ Drive remediation via custom actions (playbooks)



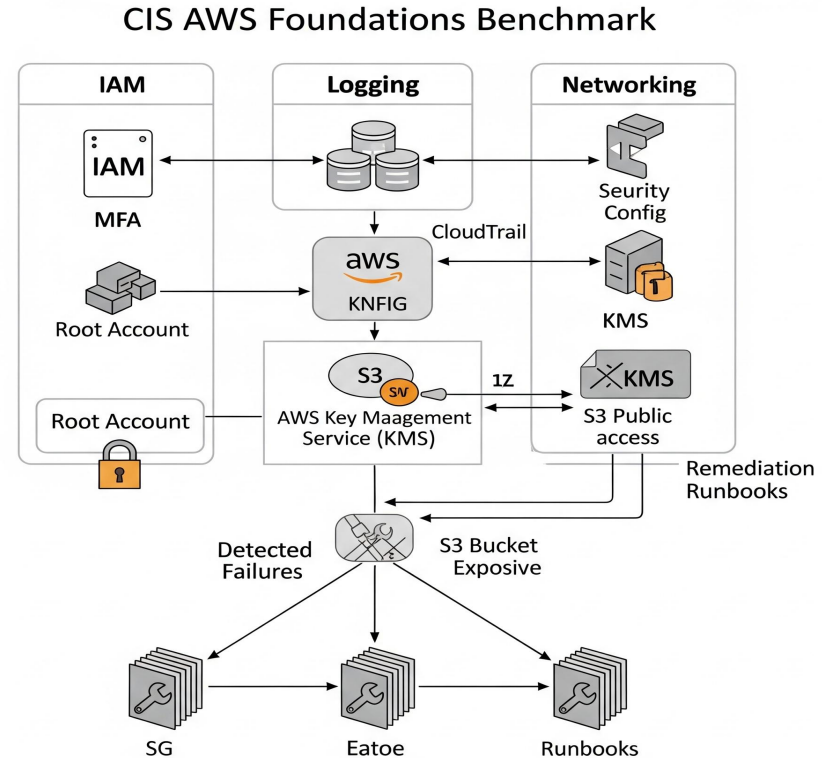
Insights & Filters

- ❖ Insights = saved queries across findings fields
- ❖ Filter by ResourceType, ComplianceStatus, Severity
- ❖ Create OU-specific or app-specific dashboards
- ❖ Track MTTR and top misconfigurations by team
- ❖ Export insights to Athena/CSV for reporting



Standards — CIS AWS Foundations

- ❖ Controls for IAM, Logging, Monitoring, Networking
- ❖ Focus on root account protections & MFA
- ❖ Central log architecture: CloudTrail, Config, S3/KMS
- ❖ Guard public exposure with S3/SG checks
- ❖ Map failures to remediation runbooks



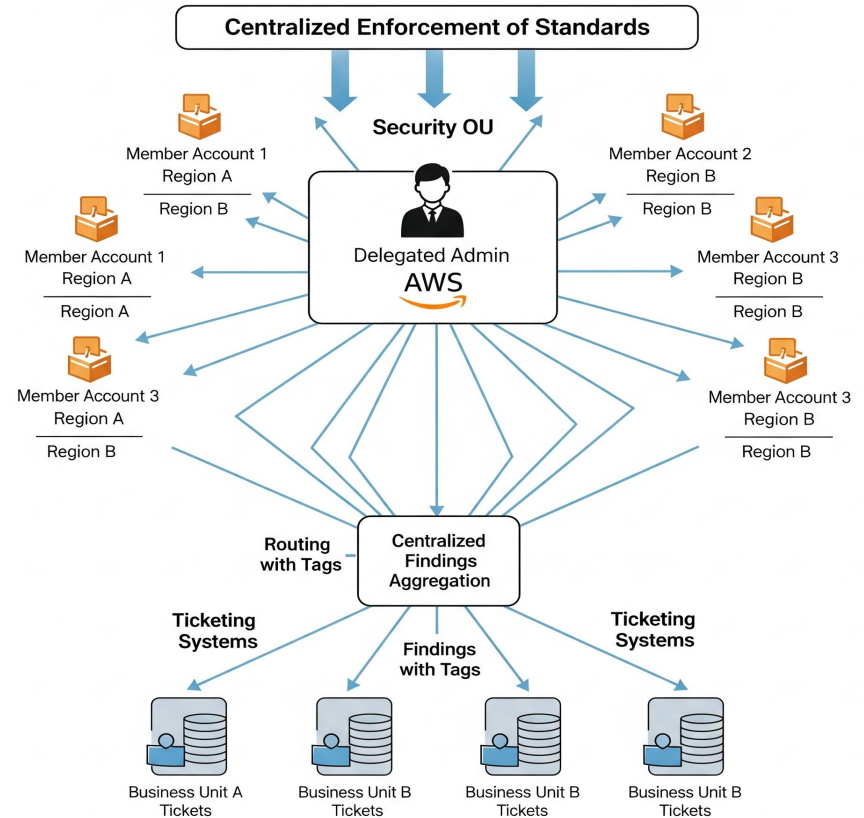
Standards — AWS Foundational Security (FSBP)

- ❖ Covers **common high-value** misconfigurations
- ❖ Aligns with services: **EC2, S3, RDS, IAM, EKS**
- ❖ Faster value than full CIS for new orgs
- ❖ Use as **default baseline** across OUs
- ❖ Extend with **custom controls** where needed



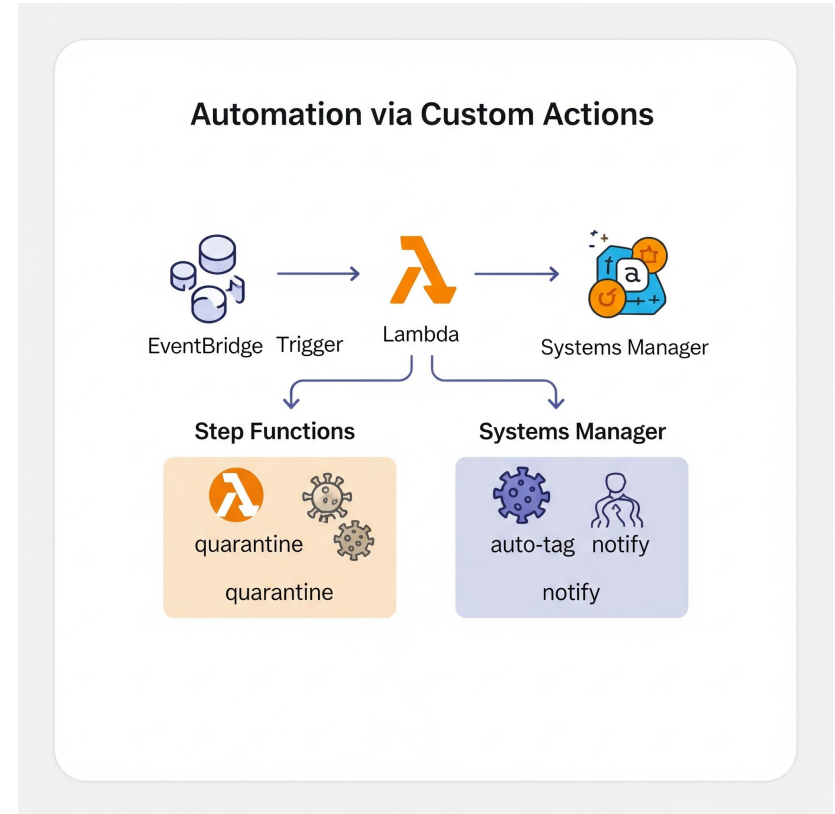
Cross-Account Aggregation

- ❖ Appoint delegated admin in Security OU
- ❖ Member accounts auto-send findings (multi-region)
- ❖ Enforce consistent standards centrally
- ❖ Use tags/resource IDs to route to right teams
- ❖ Consolidate to ticketing per business unit



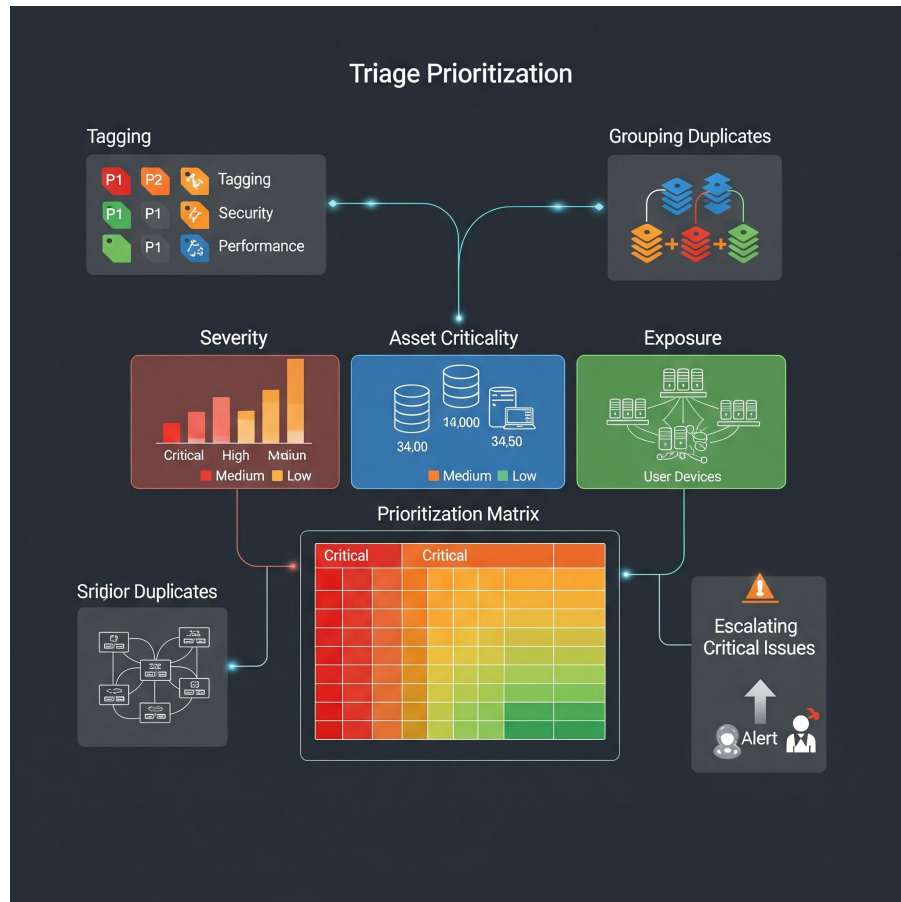
Automation via Custom Actions

- ❖ Create custom actions to send finding to EventBridge
- ❖ EventBridge target: Lambda/Step Functions/Systems Manager
- ❖ Pattern examples: quarantine, auto-tag, notify
- ❖ Store playbook ID in finding ProductFields
- ❖ Track success/failure via metrics & logs



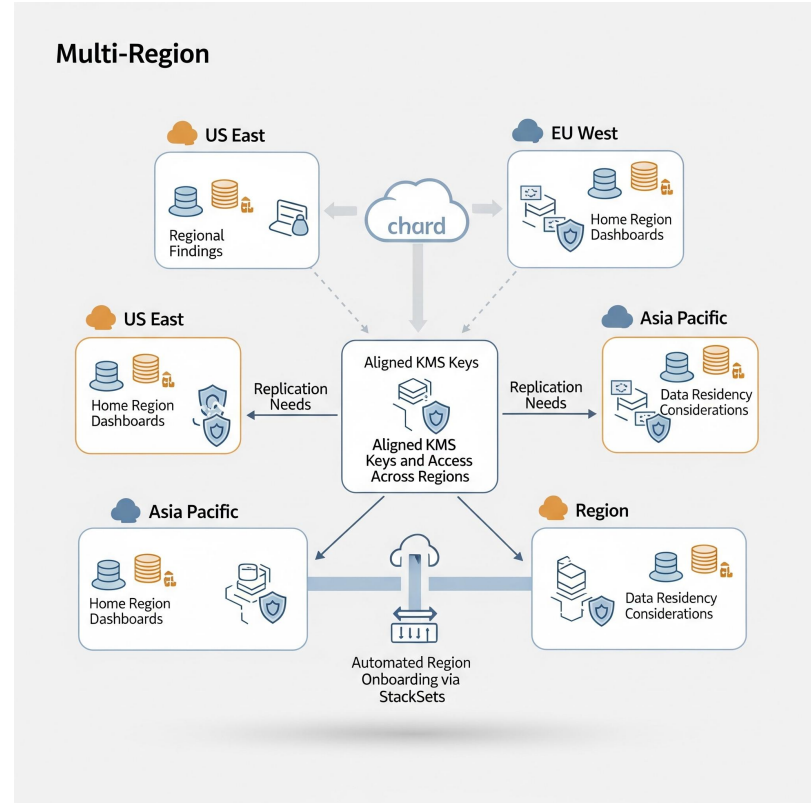
Triage Prioritization

- ❖ Prioritize by Severity × Asset Criticality × Exposure
- ❖ Add owner (tag) & environment (prod/dev) context
- ❖ Group duplicates to reduce noise (groupBy keys)
- ❖ Suppress non-actionable with documented rationale
- ❖ Aging SLAs: escalate stale criticals



Multi-Region Design

- ❖ Findings are regional; enable in all used regions
- ❖ Choose home region dashboards + replication needs
- ❖ Align KMS keys and access across regions
- ❖ Consider data residency requirements
- ❖ Automate region onboarding via StackSets



Cost & Performance Considerations

- ❖ Security Hub pricing per ingested finding & standards
- ❖ Reduce noise: tune Config rules & detector sources
- ❖ Archive benign findings using filters
- ❖ Batch remediation to avoid API throttling
- ❖ Monitor usage metrics & budget alerts

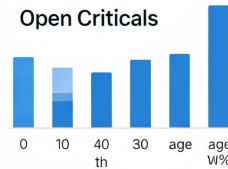


Metrics & Reporting

- ❖ KPIs: open criticals, time to remediate, recurrence
- ❖ Measure coverage: enabled accounts/regions/standards
- ❖ Weekly insight exports to leadership
- ❖ Map metrics to compliance evidence
- ❖ Use Athena + QuickSight for trend analysis

Key Performance Indicators

Open Criticals



754 ↑ +2,7% ↑

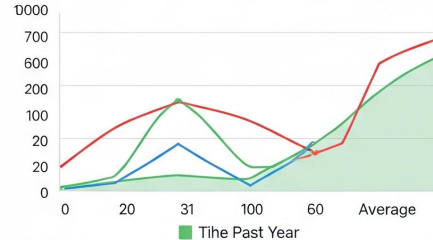
▲ Tredkal al 1%

KPI

20,49 ↑ +2,1% ↑

● Critical Alrts 9%

Time to Remedient



✓ Enabled Accounts/Regions/Standards



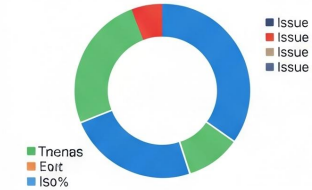
📅 Weekly Insight Exports to Leadership



✗ Map Metrics to Compliance Evidence



Recurrence



Measure Coverage



Security Hub Summary

- ❖ Central orchestration for detection & compliance
- ❖ Strong native & partner integrations
- ❖ Scale via org-wide enablement and automation
- ❖ Prioritize with context-aware insights
- ❖ Anchor for continuous improvement loops

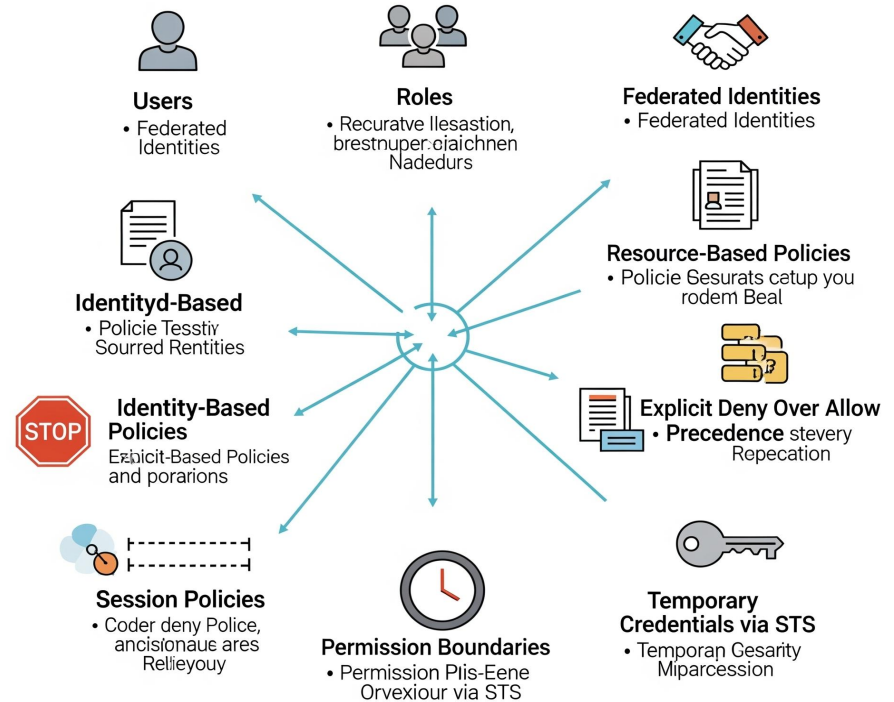


AM Best Practices, SCPs and Permission Boundaries

IAM Fundamentals

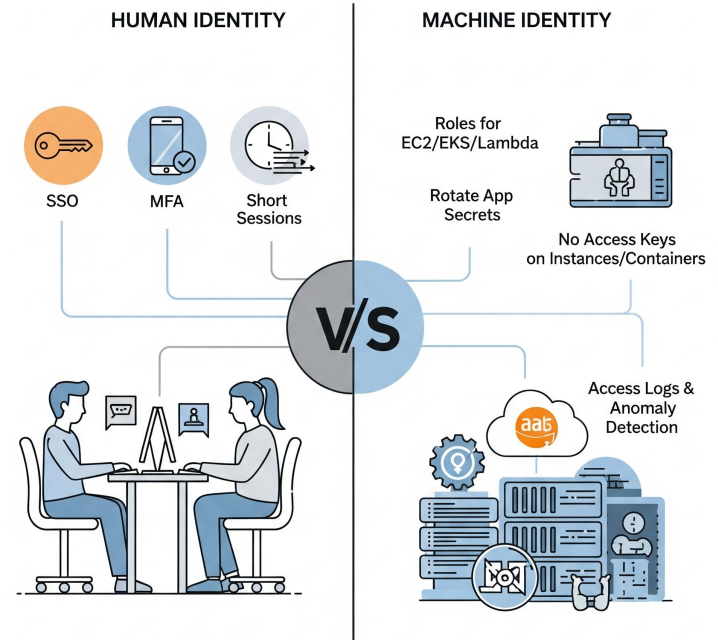
- ❖ Principals: Users, Roles, Federated identities
- ❖ Policies: identity-based vs resource-based
- ❖ Evaluation = explicit deny > allow precedence
- ❖ Session policies & permission boundaries limit scope
- ❖ Temporary creds via STS > long-lived keys

IAM FUNDAMENTALS



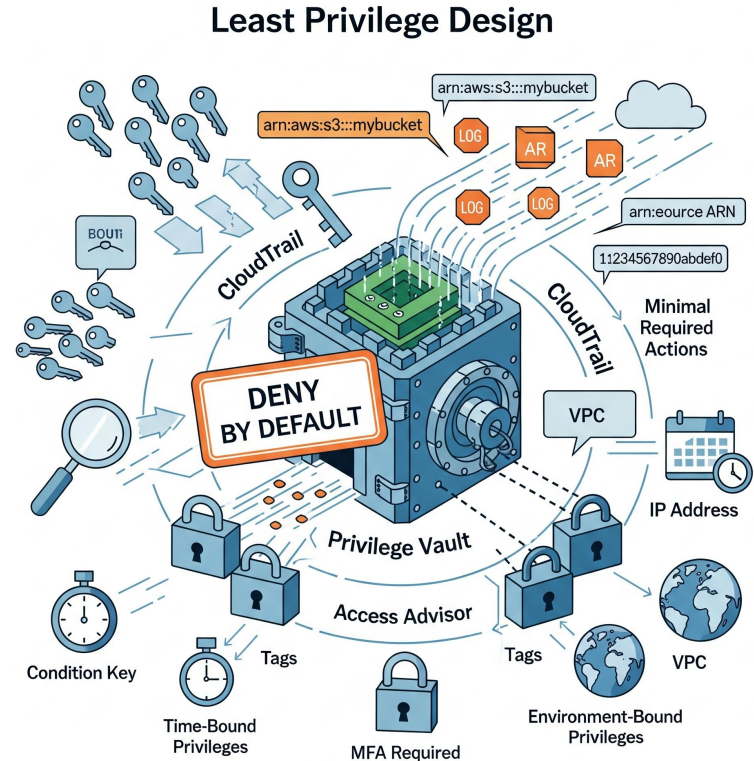
Human vs Machine Identities

- ❖ Humans: SSO + MFA + short sessions
- ❖ Machines: roles for workloads (EC2/EKS/Lambda)
- ❖ Rotate app secrets with Secrets Manager/SSM
- ❖ No access keys on instances/containers
- ❖ Instrument access logs for anomaly detection



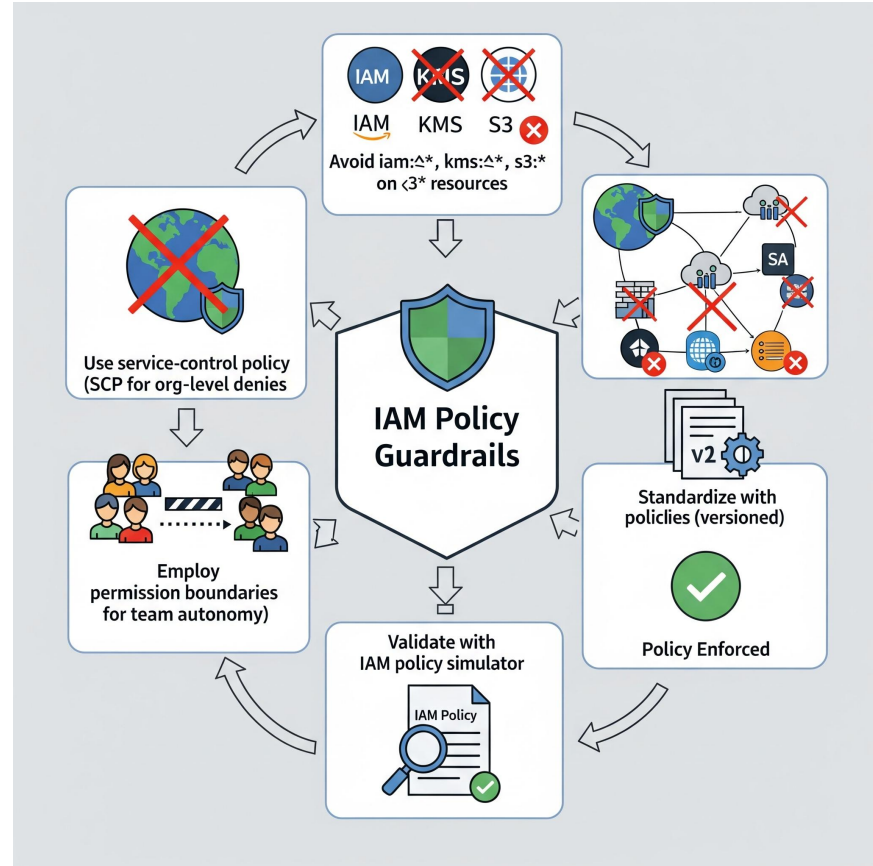
Least Privilege Design

- ❖ Start with deny-by-default; add min required actions
- ❖ Use Access Advisor & CloudTrail to refine
- ❖ Scope to resource ARNs, not *
- ❖ Condition keys: VPC, tags, IP, MFA present
- ❖ Time-bound & environment-bound privileges



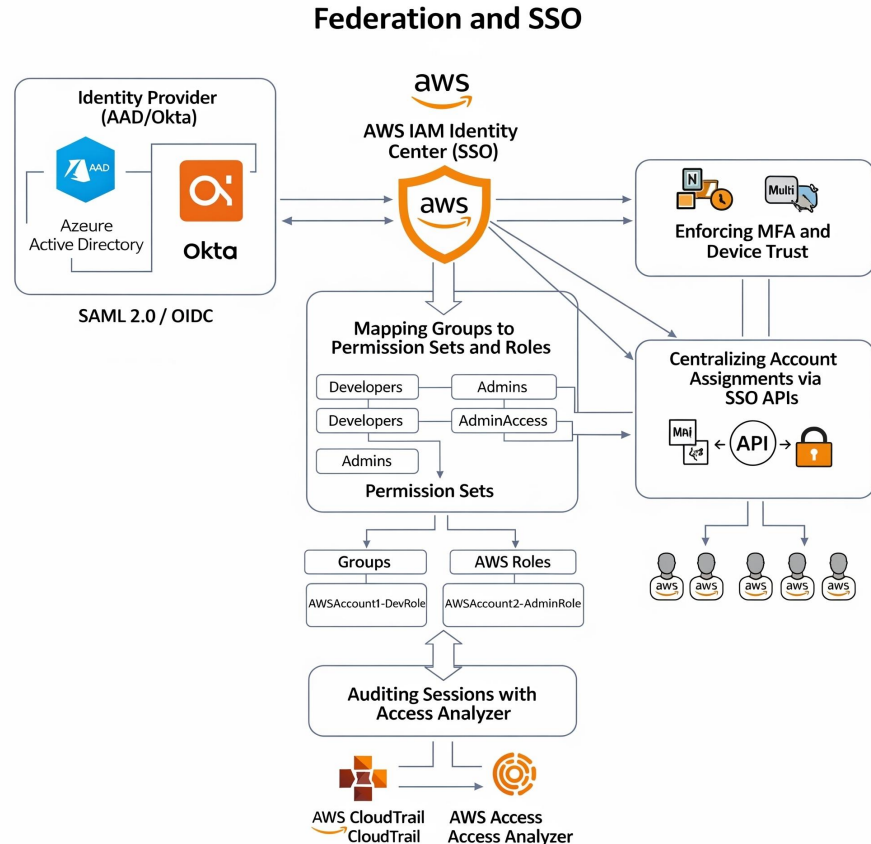
IAM Policy Guardrails

- ❖ Avoid `iam:*`, `kms:*`, `s3:*` on `*` resources
- ❖ Use service-control policy (SCP) for org-level denies
- ❖ Employ permission boundaries for team autonomy
- ❖ Standardize with managed policies (versioned)
- ❖ Validate with IAM policy simulator



Federation & SSO

- ❖ Use AWS IAM Identity Center (SSO) with IdP (AAD/Okta)
- ❖ Map groups → permission sets → roles
- ❖ Enforce MFA & device trust in IdP
- ❖ Centralize account assignments via SSO APIs
- ❖ Audit sessions with CloudTrail & Access Analyzer

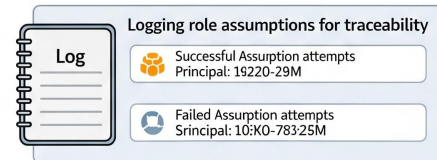
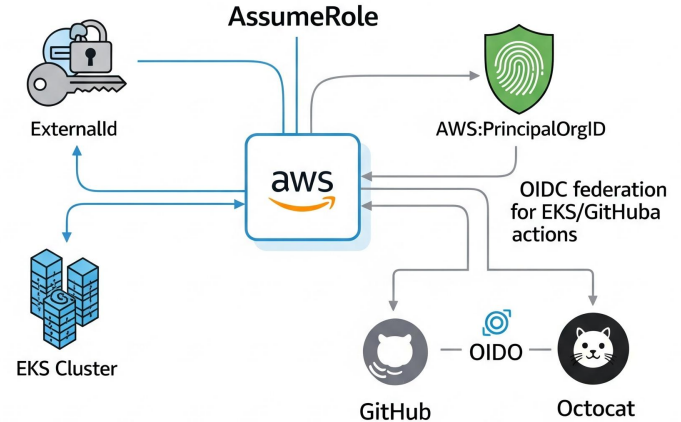


Role Trust Policies

- ❖ Limit **AssumeRole** to specific principals
- ❖ Add ExternalId / SourceIdentity where applicable
- ❖ Constrain by AWS:PrincipalOrgID for org-only trust
- ❖ Prefer OIDC federation for EKS/GitHub actions
- ❖ Log role assumptions for traceability

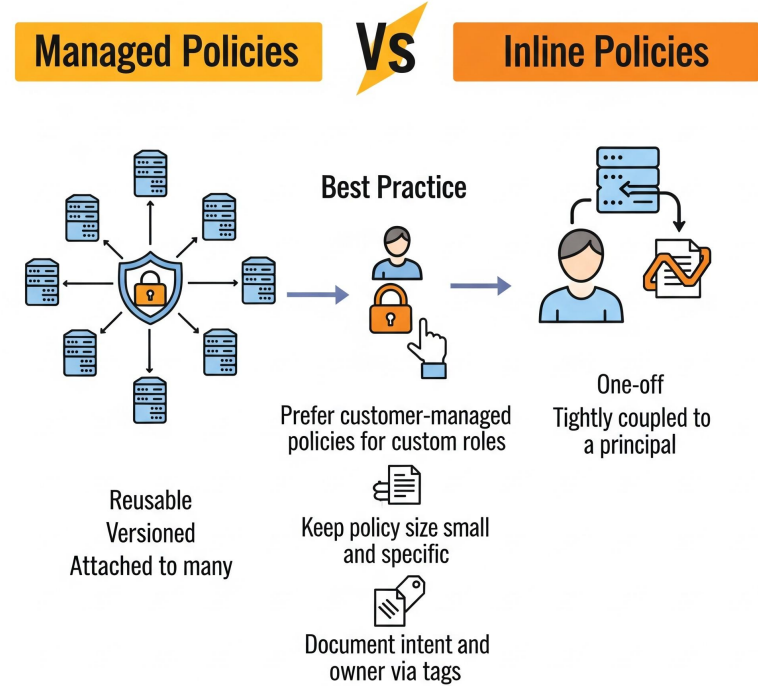
AssumeRole

AWS: is limited to specific principals



Key Managed vs Inline Policies

- ❖ Managed: reusable, versioned, attached to many
- ❖ Inline: one-off, tightly coupled to principal
- ❖ Prefer customer managed for custom roles
- ❖ Keep policy size small & specific
- ❖ Document intent and owner via tags



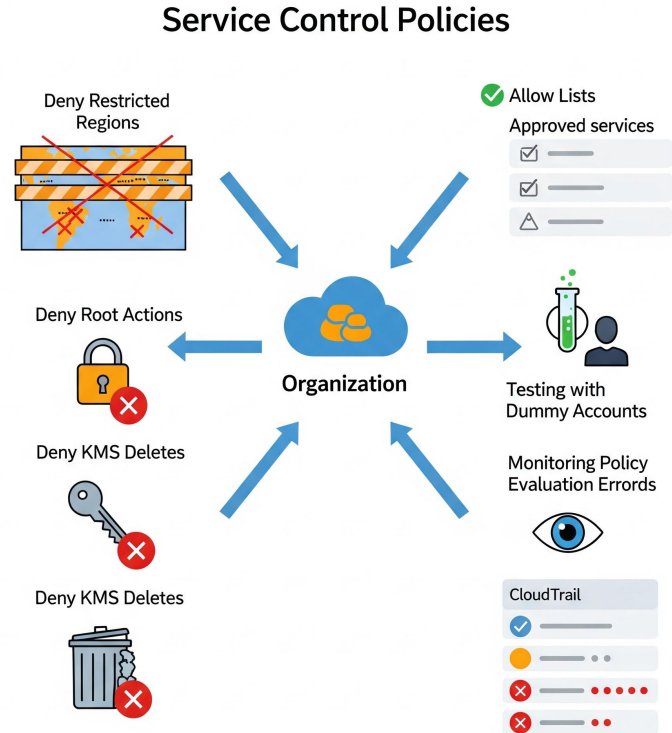
Permission Boundaries

- ❖ Upper-bound a principal's max privilege
- ❖ Enables delegation without escalation risk
- ❖ Pattern: Teams create roles within boundaries
- ❖ Common in platform engineering orgs
- ❖ Combine with SCP for layered control



Service Control Policies (SCPs)

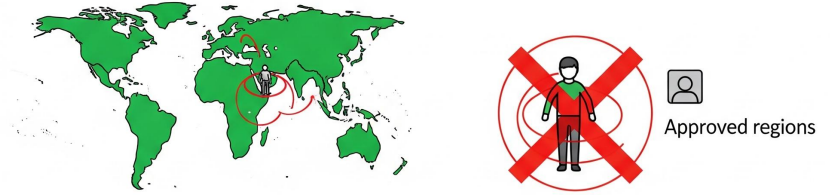
- ❖ Apply org-wide guardrails to OUs/accounts
- ❖ Deny restricted regions, root actions, KMS deletes
- ❖ Use allow lists only for minimal surface OUs
- ❖ Test with dummy accounts before rollout
- ❖ Monitor policy evaluation errors via CloudTrail



SCP Patterns

- ❖ Deny outside approved regions
- ❖ Deny leaving org (e.g., `iam:CreateAccountAlias`)
- ❖ Deny disabling security services
- ❖ Deny wildcard admin outside Security OU
- ❖ Document exceptions with OU-level overrides

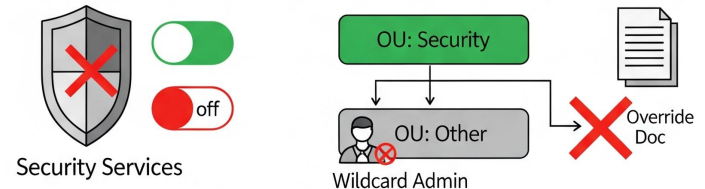
Deny outside approved regions



Deny leaving org (e.g., `iam:CreateAccountAlias`)

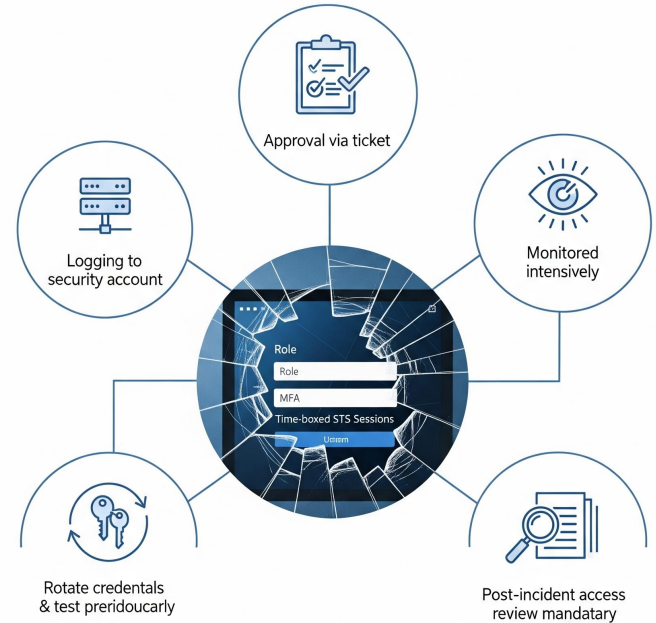


Deny disabling security services, Deny wildcard Admin outside Security OU
Document exceptions with OU-level overrides



Break-Glass Access

- ❖ Separate **break-glass role** with strict MFA
- ❖ **Time-boxed** STS sessions; monitored intensively
- ❖ Approval via **ticket** + logging to **security account**
- ❖ Post-incident **access review** mandatory
- ❖ Rotate credentials & **test** periodically



Break Glass Access

Access Reviews & Right-Sizing

- ❖ Quarterly access recertification by owners
- ❖ Use Access Analyzer findings to reduce scope
- ❖ Remove inactive roles and unused permissions
- ❖ Track reduction KPIs: permissions vs usage
- ❖ Automate via scheduled reports



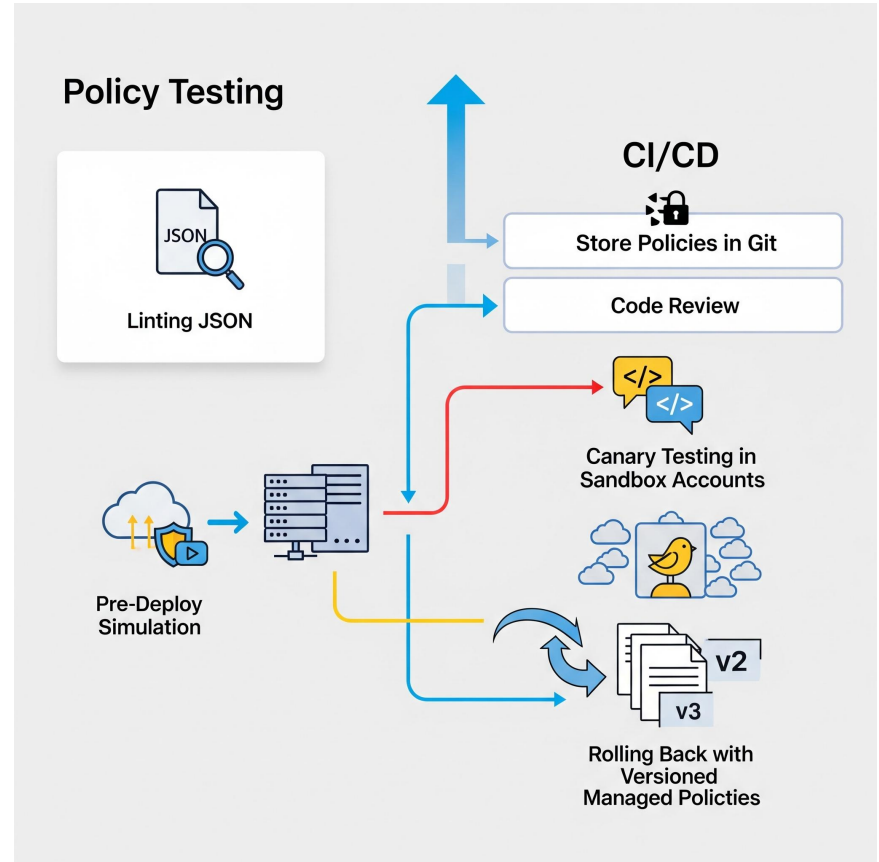
Tag-Aware Authorization

- ❖ Enforce `aws:ResourceTag/Owner` equals caller team
- ❖ Use ABAC for dynamic, large-scale control
- ❖ Tags flow from CI/CD to resources
- ❖ Prevent tag tampering with SCP/Config rules
- ❖ Audit tag coverage regularly



Policy Testing & CI/CD

- ❖ Lint JSON with **cfn-lint/opa/console validator**
- ❖ Pre-deploy **simulation** for critical roles
- ❖ Store policies in **Git** with code review
- ❖ Canary test in **sandbox** accounts first
- ❖ Rollback with **versioned managed policies**



IAM Program Summary

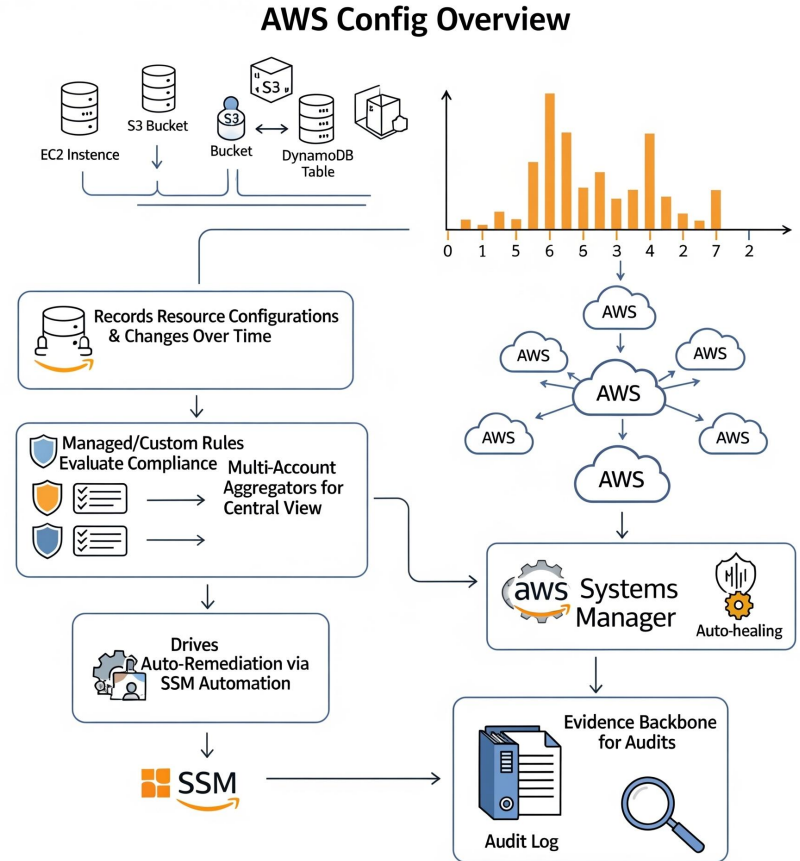
- ❖ Identity-first security with **least privilege**
- ❖ **Federation & SSO** for human access
- ❖ **SCPs + permission boundaries** = safe scale
- ❖ **Analyzer** + reviews to stay current
- ❖ Codify identity as **policy-as-code**



AWS Config

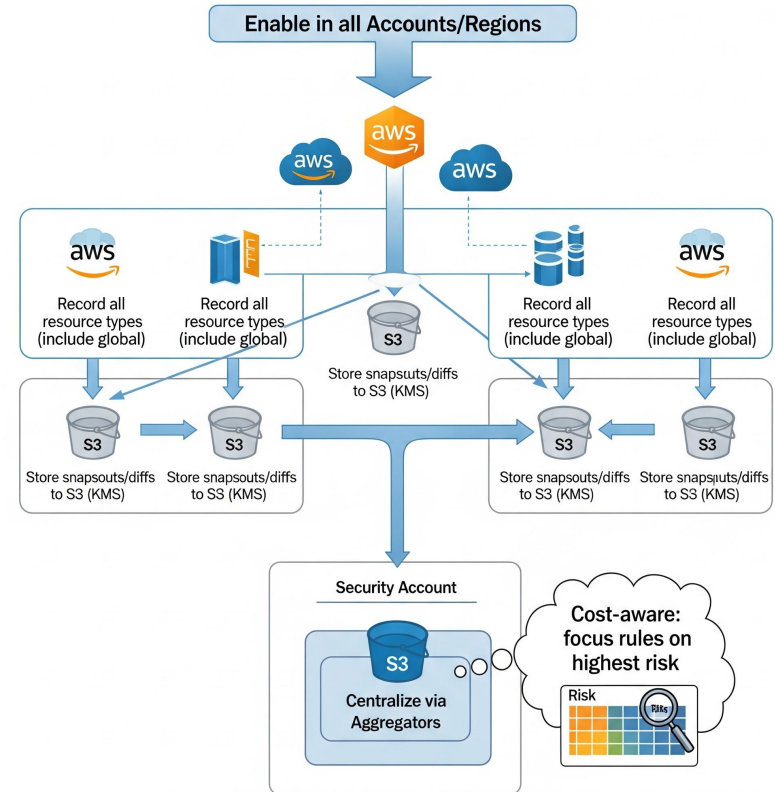
AWS Config Overview

- ❖ Records resource configurations & changes over time
- ❖ Managed/custom rules evaluate compliance
- ❖ Multi-account aggregators for central view
- ❖ Drives auto-remediation via SSM Automation
- ❖ Evidence backbone for audits



Designing Config Coverage

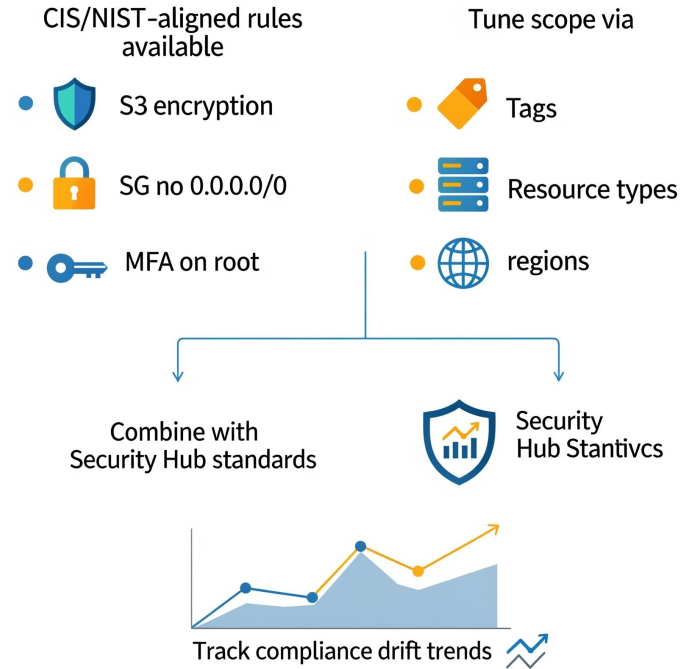
- ❖ Enable in all accounts/regions
- ❖ Record all resource types (include global)
- ❖ Store snapshots/diffs to S3 (KMS)
- ❖ Centralize via aggregators in Security account
- ❖ Cost-aware: focus rules on highest risk



Config Managed Rules

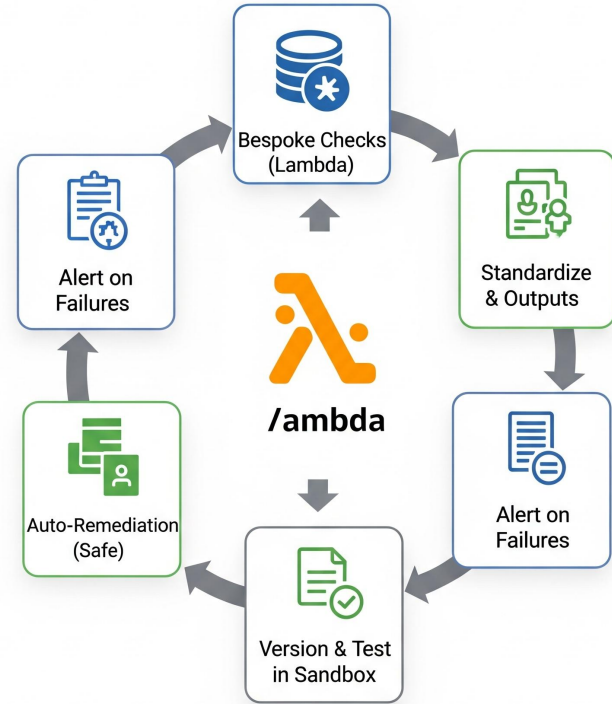
- ❖ Baseline: CIS/NIST-aligned rules available
- ❖ Examples: S3 encryption, SG no 0.0.0.0/0, MFA on root
- ❖ Tune scope via tags, resource types, regions
- ❖ Combine with Security Hub standards
- ❖ Track compliance drift trends

Config Managed Rules - Baseline



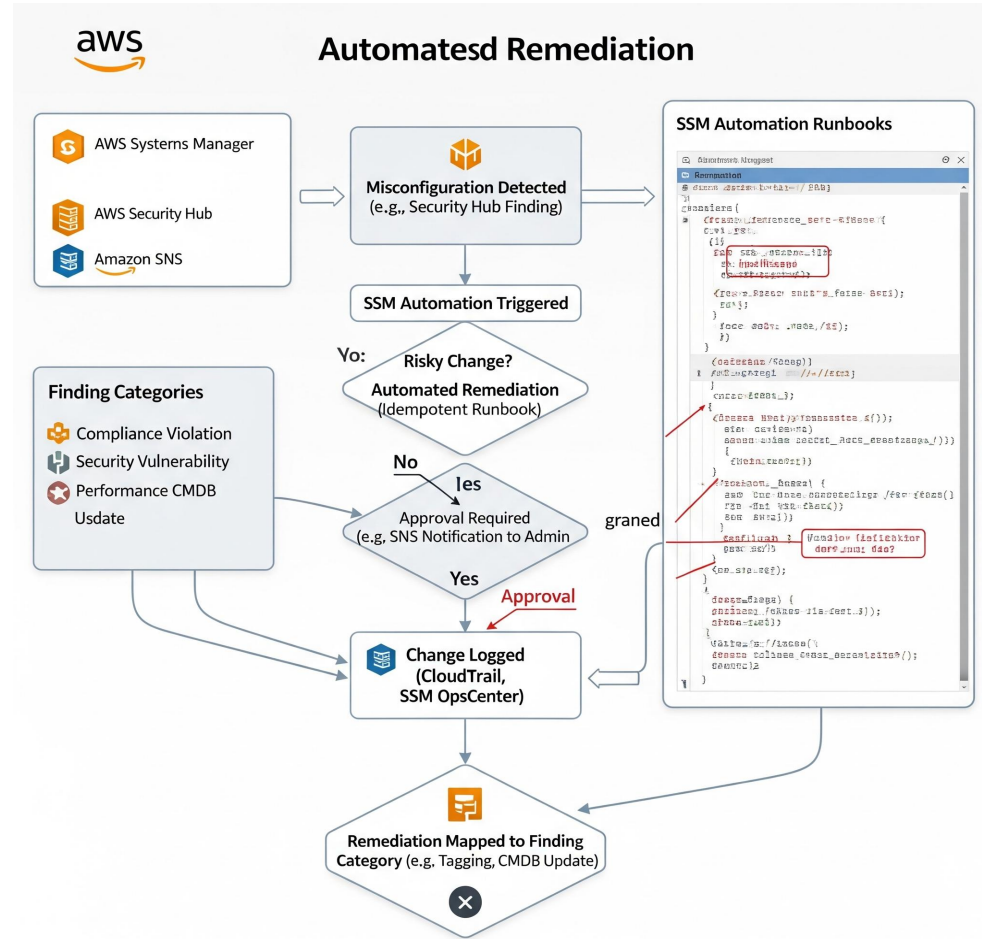
Config Custom Rules

- ❖ Use Lambda for bespoke checks
- ❖ Standardize names & outputs for dashboards
- ❖ Version & test in sandbox first
- ❖ Add auto-remediation actions where safe
- ❖ Alert on rule failures (not just non-compliance)



Config Remediation

- ❖ SSM Automation docs fix known misconfigs
- ❖ Require approval for risky changes
- ❖ Log changes to Change Manager/CloudTrail
- ❖ Idempotent runbooks for repeatability
- ❖ Map remediations to finding categories

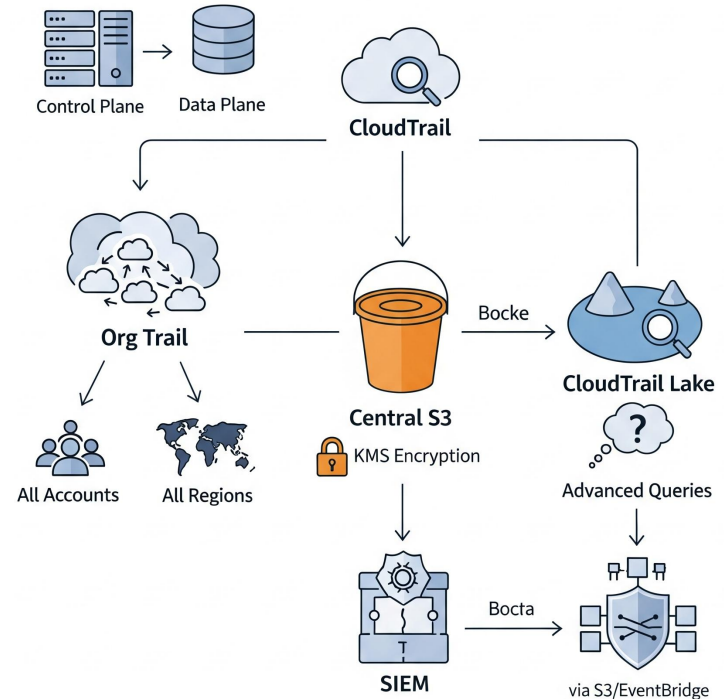


CloudTrail

CloudTrail Essentials

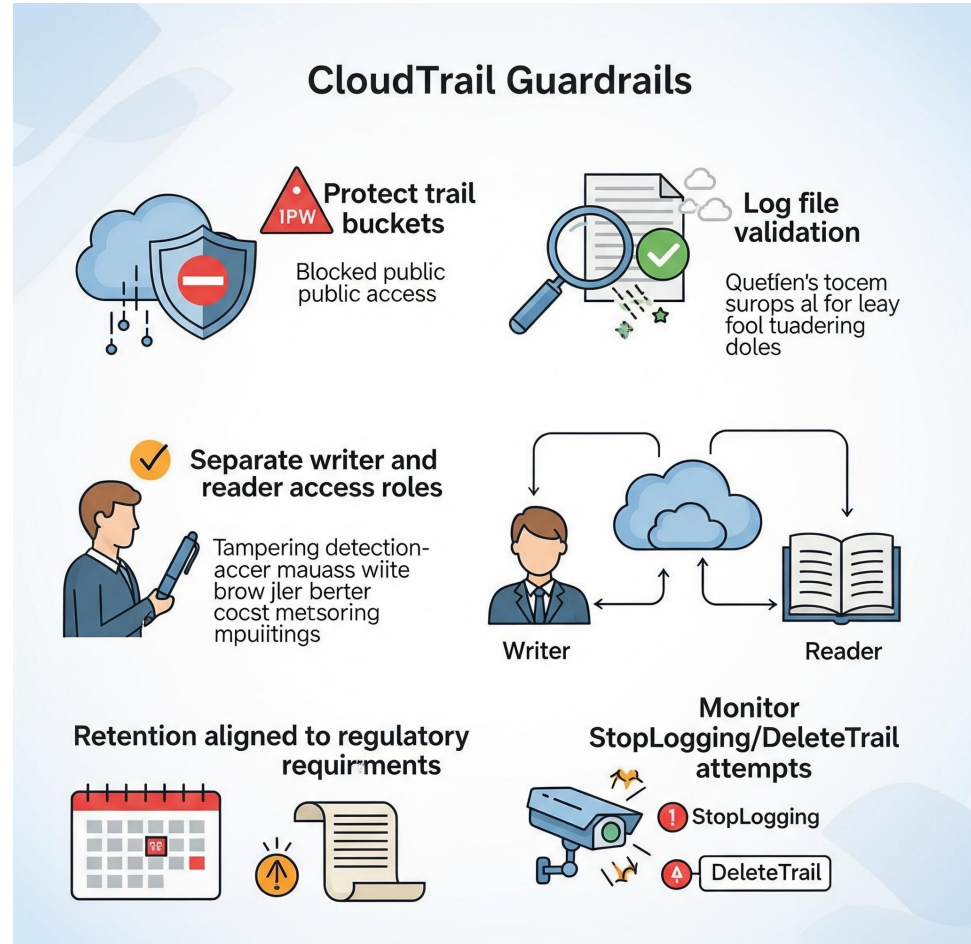
- ❖ Records **control-plane** (and some data-plane) API calls
- ❖ Create **org trail** to cover all accounts/regions
- ❖ Deliver to **central S3** with **KMS** encryption
- ❖ Enable **CloudTrail Lake** for advanced queries
- ❖ Forward to **SIEM** via **S3/EventBridge**

CloudTrail Essentials



CloudTrail Guardrails

- ❖ Protect trail buckets (block public access)
- ❖ **Log file validation** to detect tampering
- ❖ Separate **writer** and **reader** access roles
- ❖ Retention aligned to **regulatory** requirements
- ❖ Monitor **StopLogging/DeleteTrail** attempts



GuardDuty

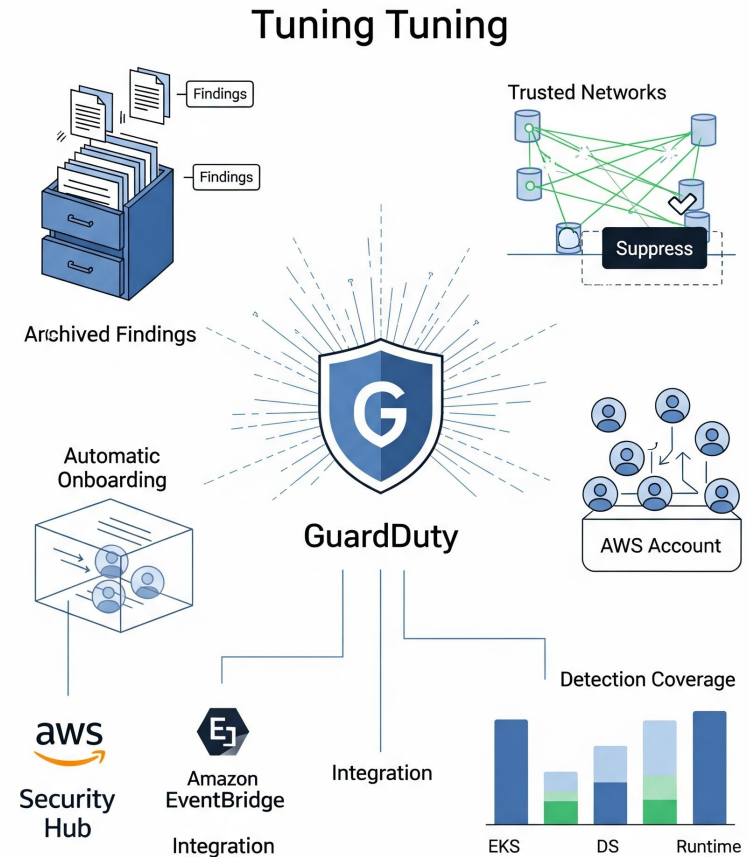
GuardDuty Overview

- ❖ ML-powered **threat detection** service
- ❖ Monitors **CloudTrail, VPC Flow, DNS, EKS Audit**
- ❖ Findings: **recon, credential compromise, crypto-mining**
- ❖ Org-level enablement with **delegated admin**
- ❖ Low-ops, high-signal starting point



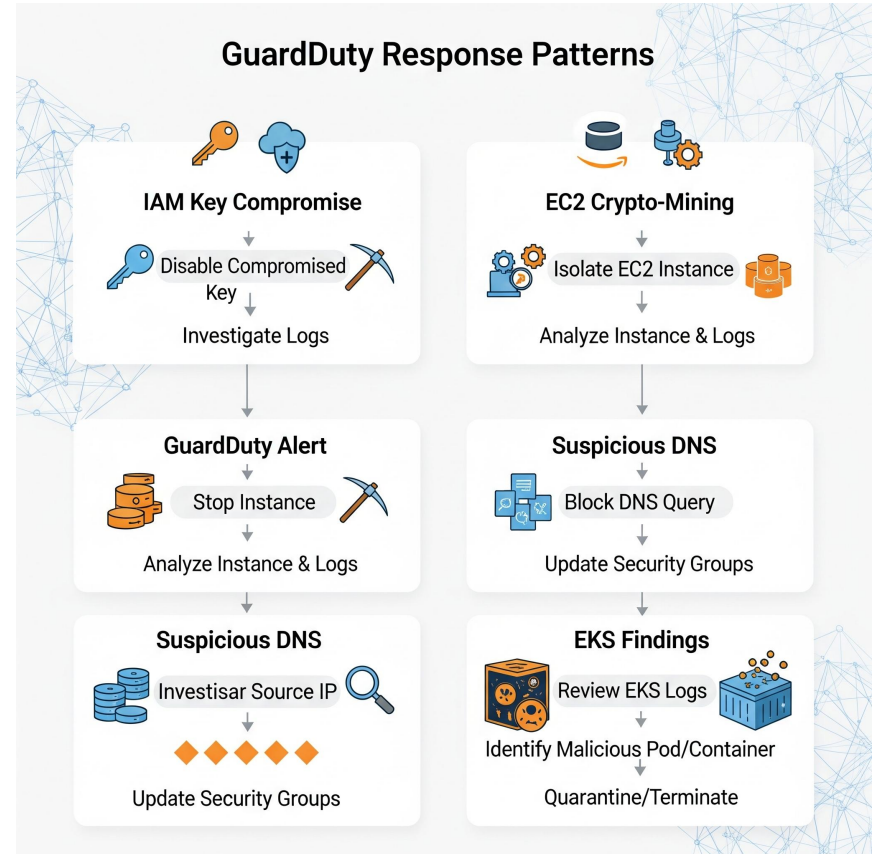
GuardDuty Tuning

- ❖ Archive benign findings (IP reputation exceptions)
- ❖ Suppress based on **trusted networks**
- ❖ Integrate with **Security Hub & EventBridge**
- ❖ Onboard new accounts **automatically**
- ❖ Track **detection coverage** (EKS/DS/Runtime where used)



GuardDuty Response Patterns

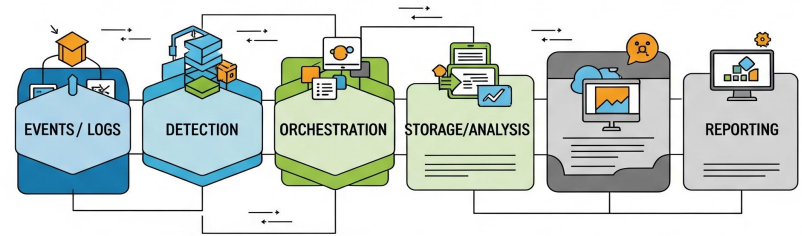
- ❖ **IAM key compromise** → disable key, rotate, scope blast
- ❖ **EC2 crypto-mining** → isolate SG/NACL, snapshot, forensics
- ❖ **Suspicious DNS** → block domains/IP via **Network Firewall**
- ❖ **EKS findings** → enforce **PodSecurity/IR** playbooks
- ❖ Always **ticket + post-incident review**



End-to-End Telemetry Flow

- ❖ Events/logs → CloudWatch/CloudTrail/Flow Logs
- ❖ Detection → GuardDuty/Config/Security Hub
- ❖ Orchestration → EventBridge/Lambda/SSM
- ❖ Storage/analysis → S3/Athena/QuickSight
- ❖ Reporting → dashboards & compliance exports

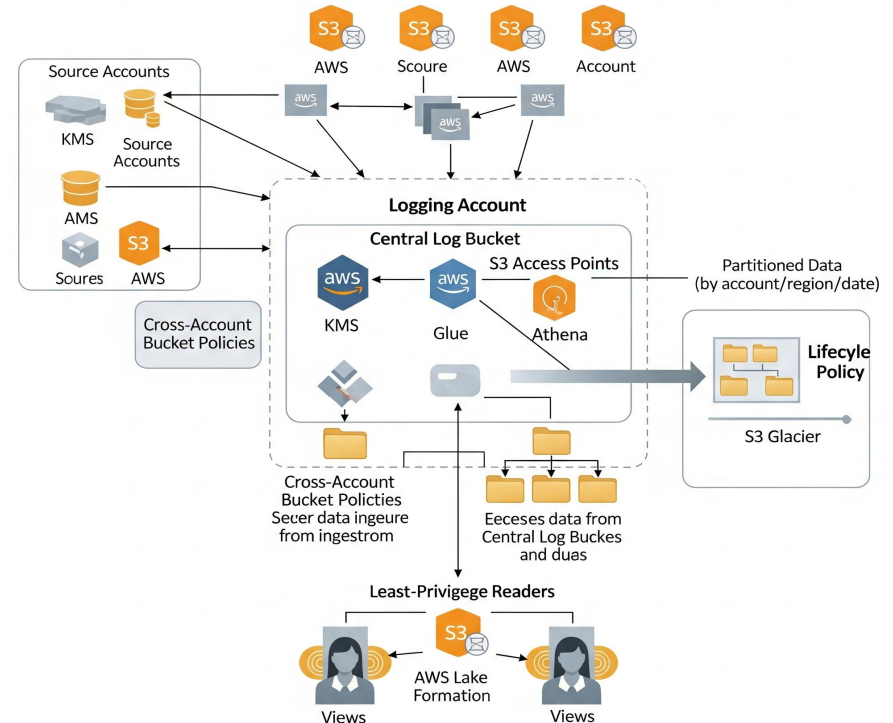
END-TO-END TELEMETRY FLOW



Centralized Logging Architecture

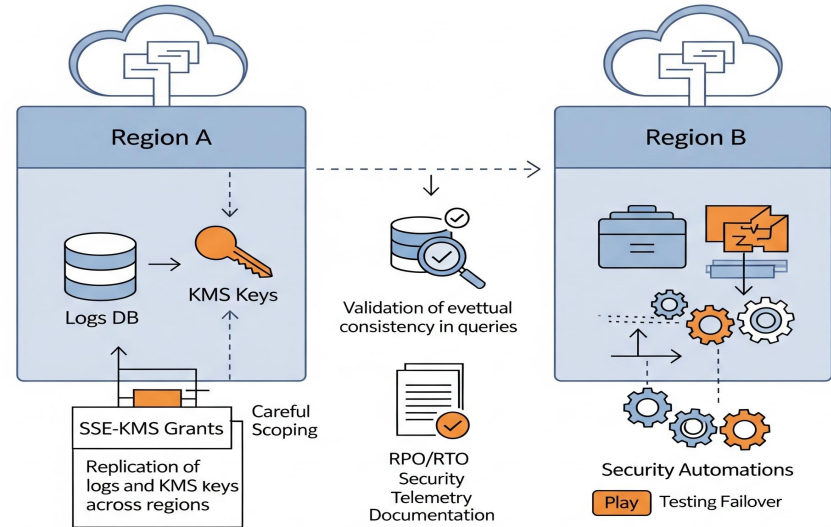
- **Dedicated logging account** (S3/KMS/Glue/Athena)
- Cross-account **bucket policies** + **S3 Access Points**
- Partitioned data (by **account/region/date**)
- Lifecycle policies to **S3 Glacier** for cost
- Least-privilege **readers** via Lake/Views

Centralized Logging System



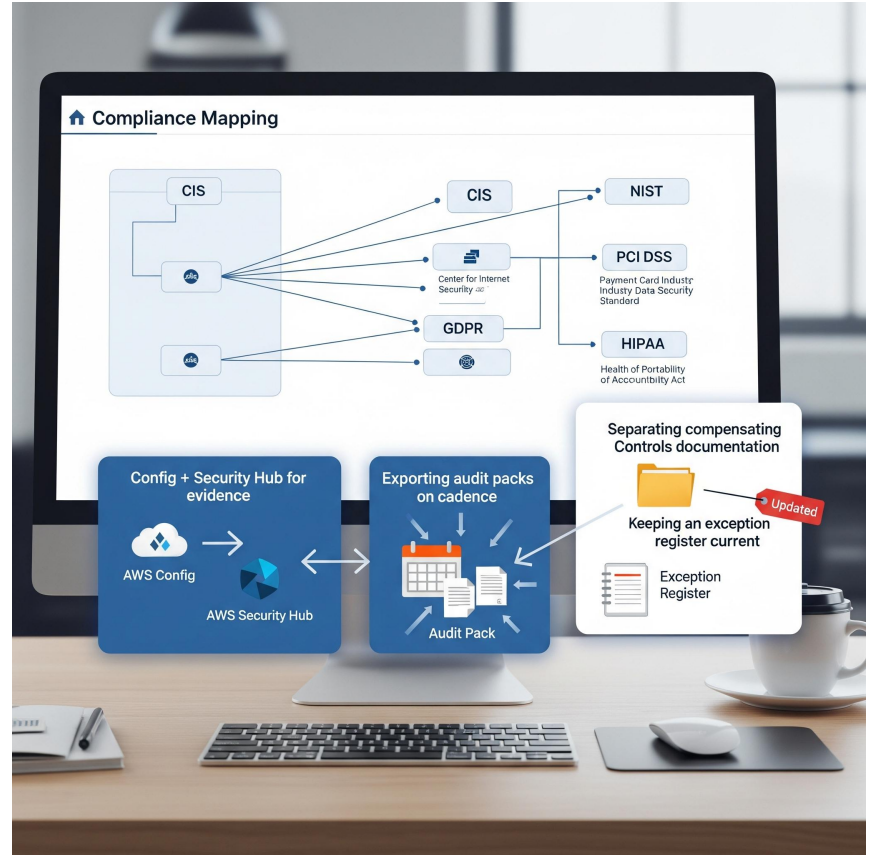
Multi-Region & DR Considerations

- ❖ Replicate logs/KMS keys where required
- ❖ Carefully scope **SSE-KMS** grants across regions
- ❖ Validate **eventual consistency** in queries
- ❖ Document **RPO/RTO** for security telemetry
- ❖ Test **failover** of security automations



Compliance Mapping

- ❖ Map controls to **CIS/NIST/PCI/GDPR/HIPAA**
- ❖ Use **Config + Security Hub** for evidence
- ❖ Export **audit packs** on cadence
- ❖ Separate **compensating controls** documentation
- ❖ Keep **exception register** current



Ops Maturity Checklist

- ❖ Org-wide **CloudTrail**, **Config**, **GuardDuty** enabled
- ❖ **Security Hub** standards enforced & tuned
- ❖ **SCPs** + **boundaries** in place
- ❖ Automated **remediation** for common issues
- ❖ **Metrics** driving continuous improvement

Operations Maturity Checklist



Org-wide CloudTrail Enablement



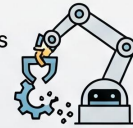
Org-wide Config Enablement



GuardDuty Enablement



Enforced & Tuned Security Hub Standards



SCPs & Permission Boundaries In Place



Automated Remediation for Common Issues



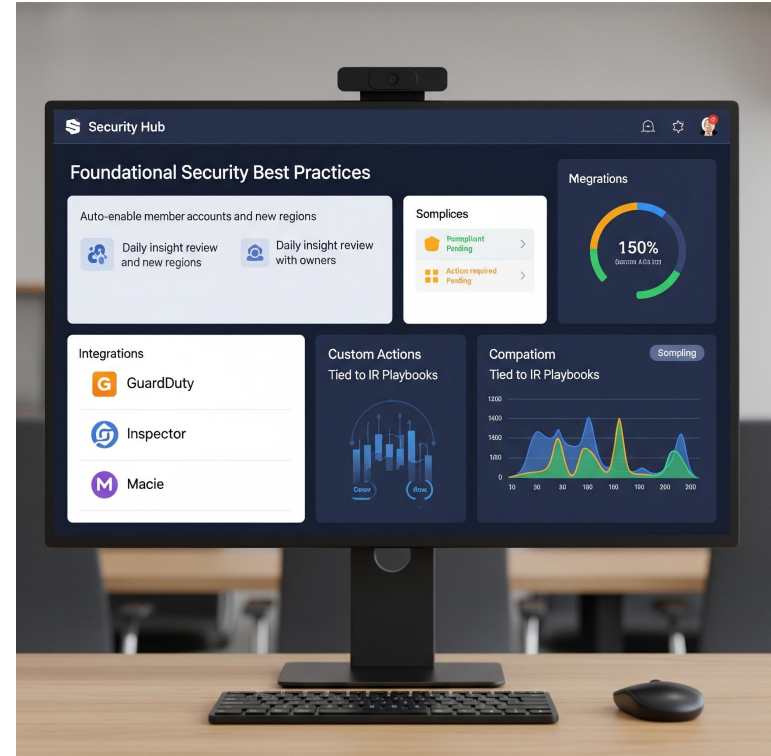
Metrics Driving Continuous Improvement



Key Tools

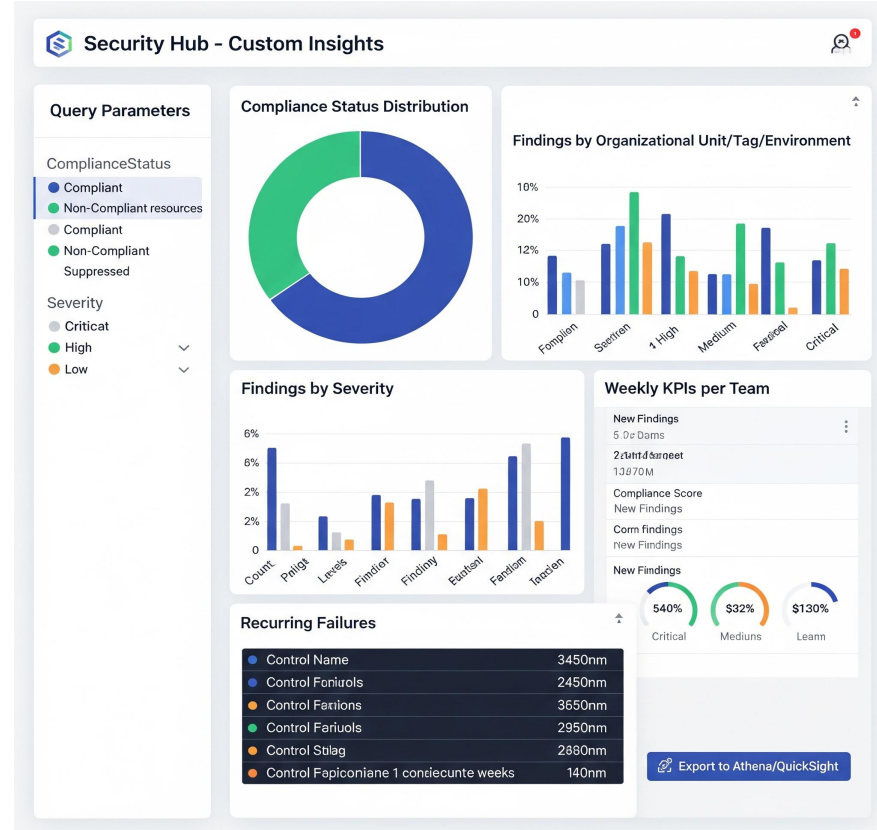
Security Hub — What to Turn On First

- ❖ **Foundational Security Best Practices** standard
- ❖ **Auto-enable** member accounts & new regions
- ❖ **GuardDuty, Inspector, Macie** integrations
- ❖ **Custom actions** tied to IR playbooks
- ❖ **Daily insight review** with owners



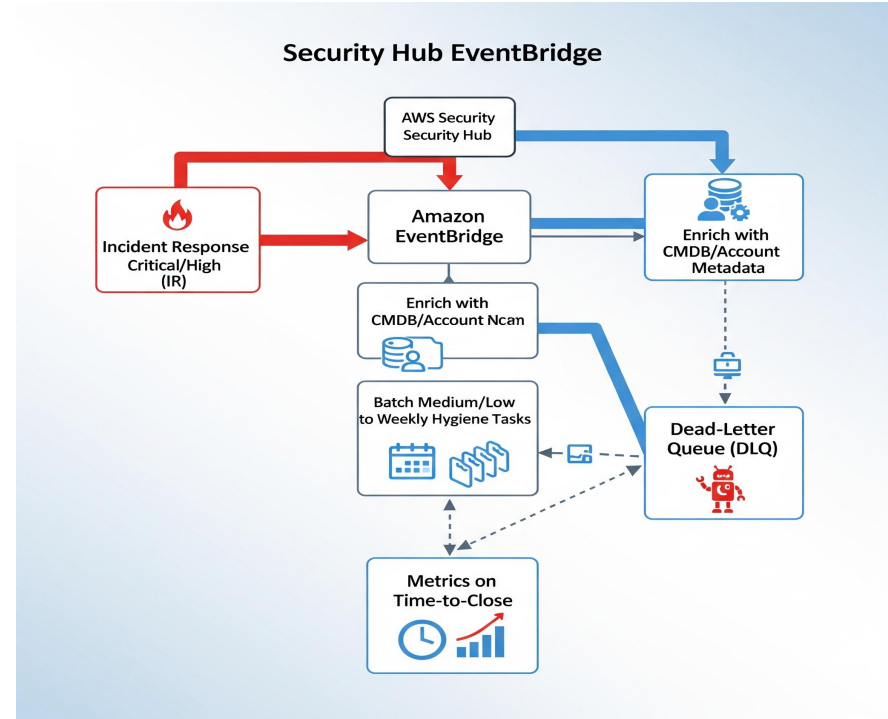
Security Hub — Custom Insights

- Query by **ComplianceStatus & Severity**
- Slice by **OU/Tag/Environment**
- Track **recurring failures** (same control)
- Publish **weekly KPIs** per team
- Export to **Athena/QuickSight**



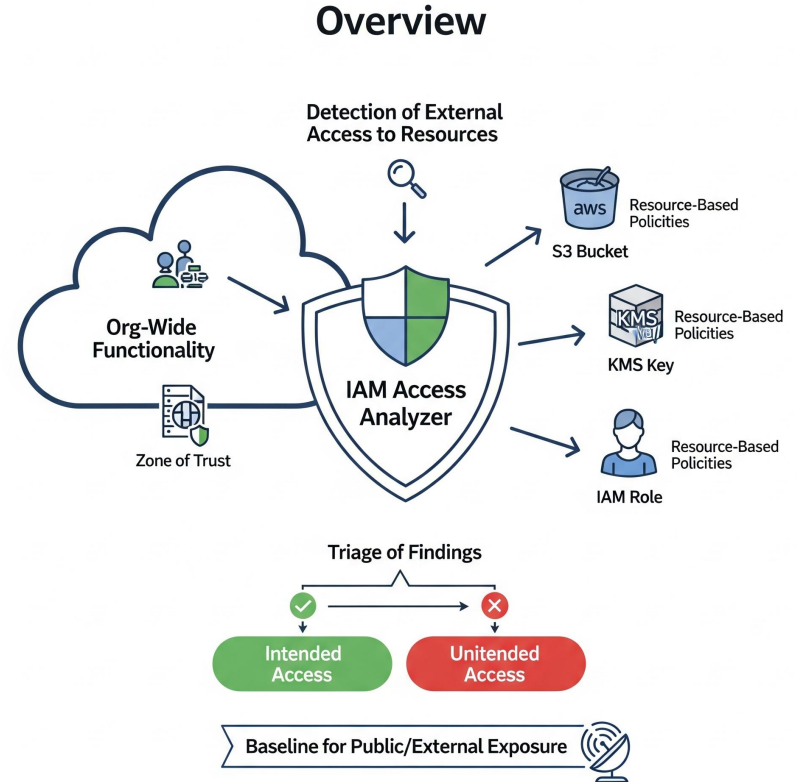
Security Hub — EventBridge Patterns

- ❖ Route **Critical/High** immediately to IR
- ❖ **Enrich** with CMDB/account metadata
- ❖ **Batch** medium/low to weekly hygiene tasks
- ❖ DLQ for **failed automations**
- ❖ Metrics on **time-to-close**



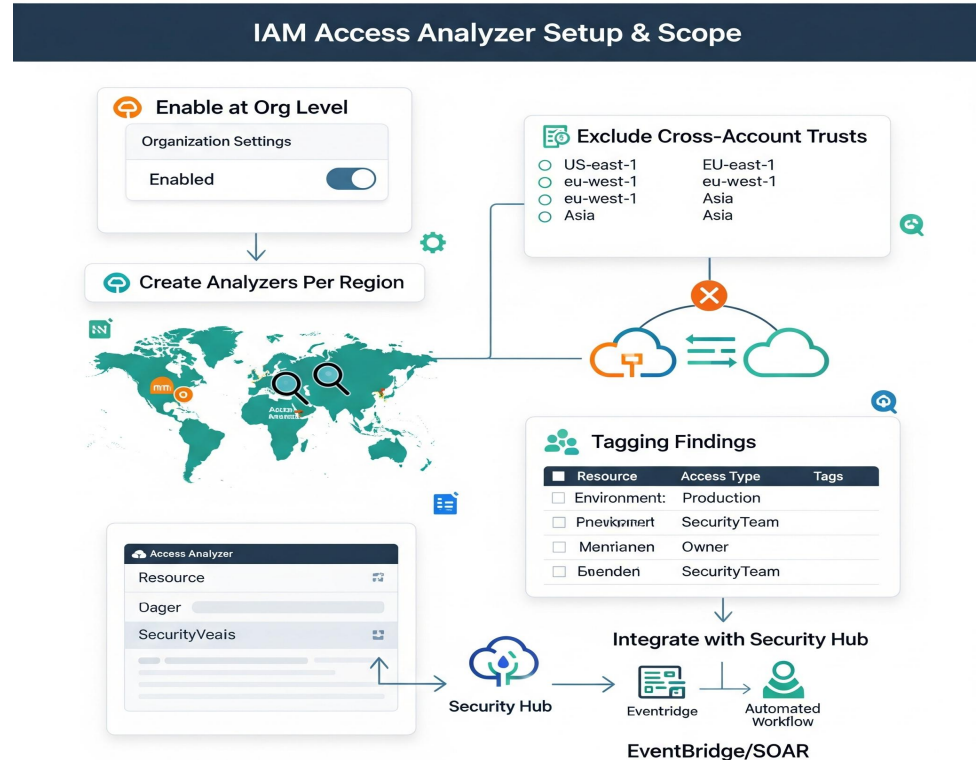
IAM Access Analyzer — Overview

- ❖ Detects **external access** to resources
- ❖ Analyzes **resource-based policies** (S3/KMS/IAM roles/etc.)
- ❖ Works **org-wide** with zone of trust
- ❖ Findings triaged by **intended vs unintended** access
- ❖ Baseline for **public/external exposure**



IAM Access Analyzer — Setup & Scope

- ❖ Enable at **org level** with trusted org ID
- ❖ Create analyzers per **region** as needed
- ❖ Exclude **known cross-account trusts** via archive rules
- ❖ Tag findings with **owner/team**
- ❖ Integrate to **Security Hub** via EventBridge/SOAR



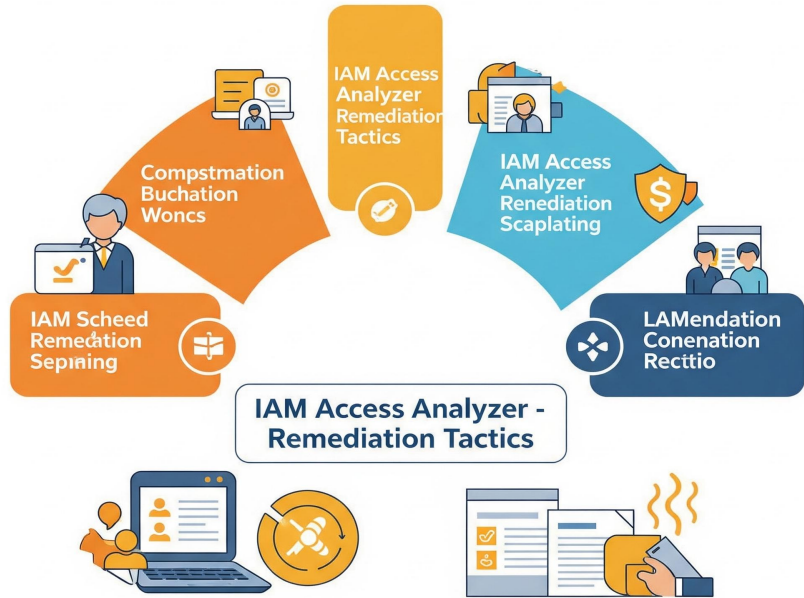
IAM Access Analyzer — Common Findings

- ❖ **S3 bucket** public READ/WRITE
- ❖ **KMS key** shared with external account
- ❖ **IAM role** assumable by * or broad principals
- ❖ **SQS/SNS** policies with public **Principal**
- ❖ **ECR** repository push/pull exposure



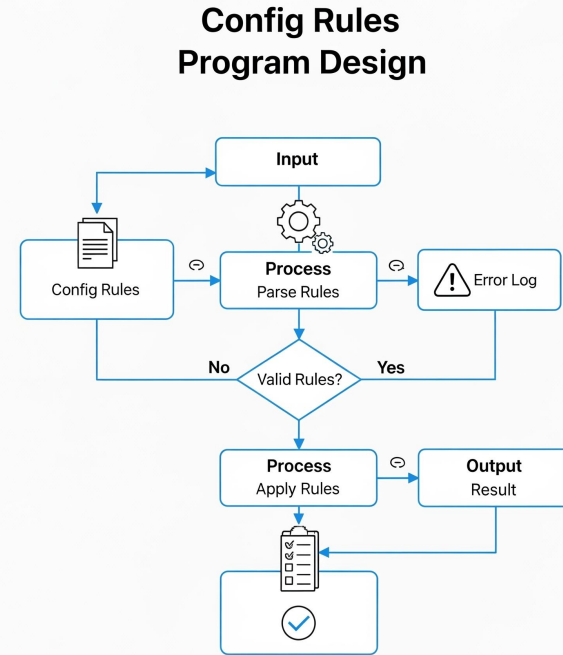
IAM Access Analyzer — Remediation Tactics

- ❖ Lock down **Principal** and **Condition** keys
- ❖ Enforce **aws:PrincipalOrgID** where cross-account needed
- ❖ Use **VPC endpoints + S3 bucket policies**
- ❖ Rotate access patterns through **role assumption**
- ❖ Validate with **policy simulator** before deploy



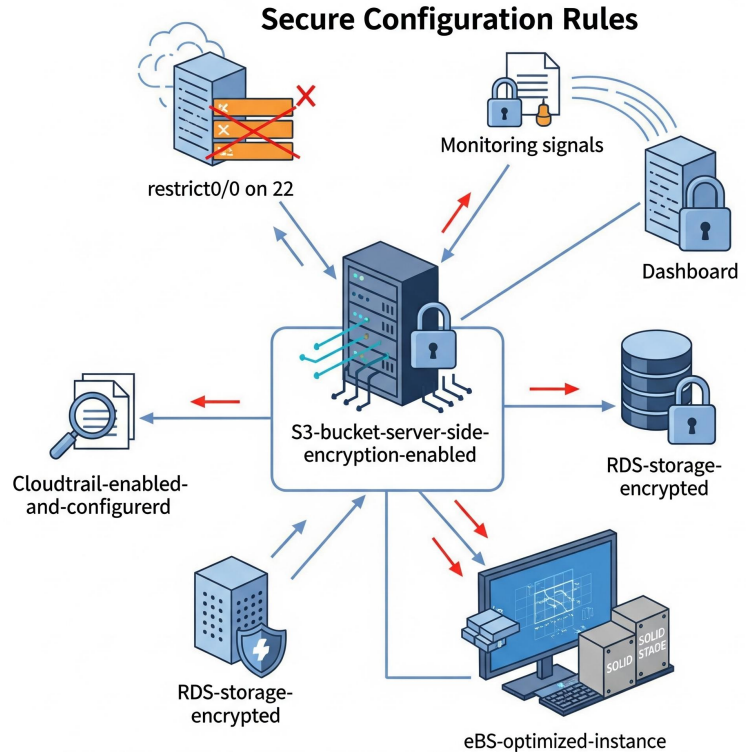
Config Rules — Program Design

- ❖ Start with **top 10** misconfig controls
- ❖ Map each rule to an **owner** & **remediation**
- ❖ Gate risky remediations with **approvals**
- ❖ Publish **coverage** and **false-positive** rates
- ❖ Iterate rules quarterly with lessons learned



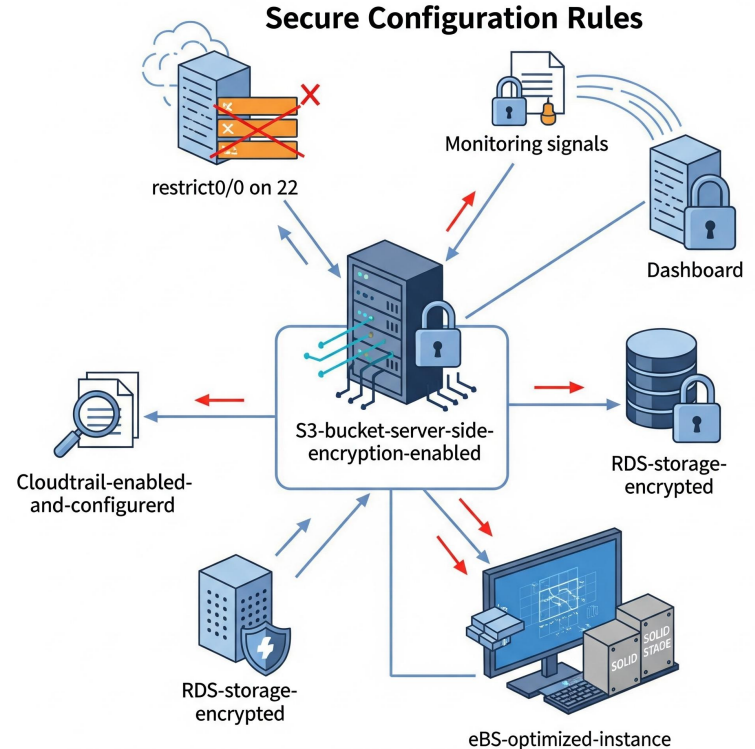
Config Rules — High-Value Examples

- ❖ s3-bucket-server-side-encryption-enabled
- ❖ restricted-ssh (no 0.0.0.0/0 on 22)
- ❖ cloudtrail-enabled-and-configured
- ❖ rds-storage-encrypted
- ❖ ebs-optimized-instance where applicable



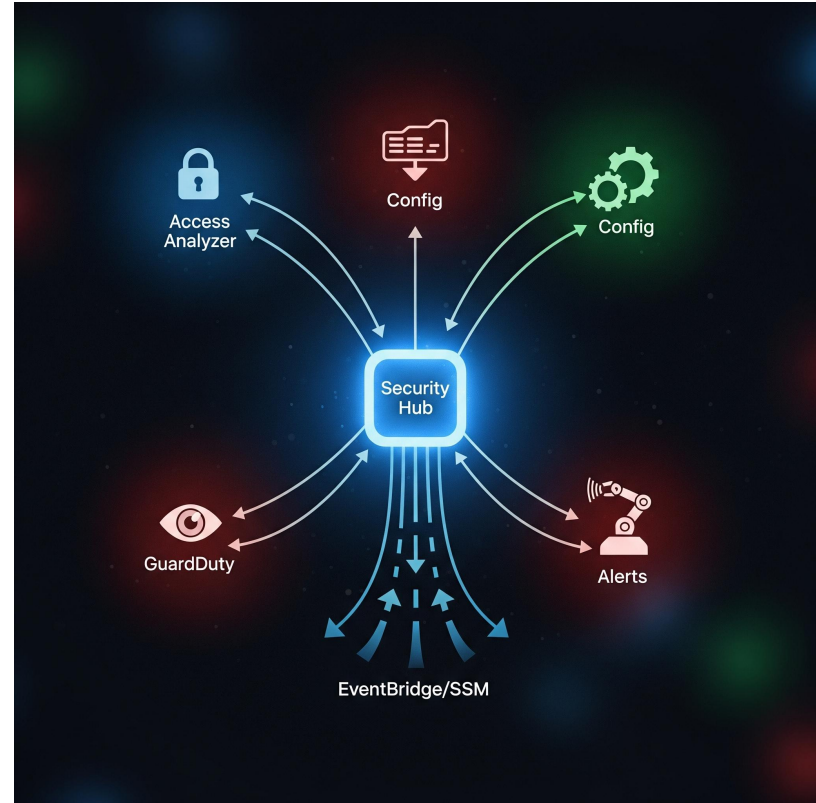
Config Rules — Custom Lambda Tips

- ❖ Reuse **utility layers** (logging, metrics, SDK init)
- ❖ Timeouts and **idempotent logic**
- ❖ Structured outputs for **Security Hub**
- ❖ Handle **throttling** with retries/backoff
- ❖ Cost guardrails: **batch** evaluations



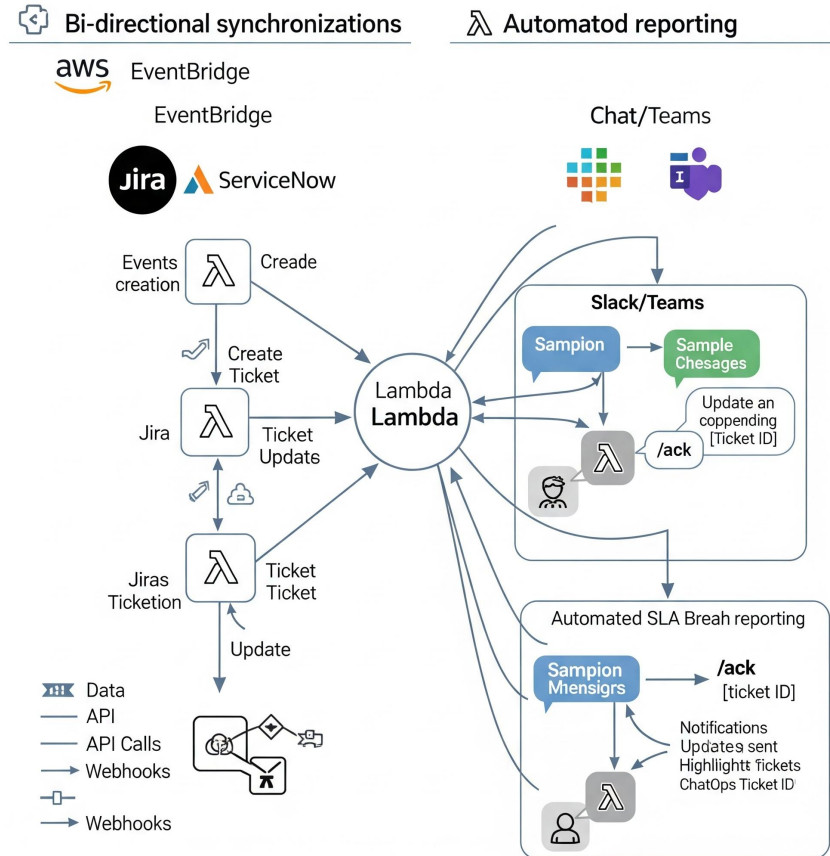
Joining the Dots — Toolchain

- ❖ Access Analyzer prevents exposure
- ❖ Config enforces desired state
- ❖ GuardDuty detects active threats
- ❖ Security Hub triages & orchestrates
- ❖ EventBridge/SSM execute remediations



Ticketing & ChatOps Integration

- ❖ EventBridge → **Lambda** → **Jira/ServiceNow** ticket
- ❖ **Slack/Teams** notifications with deep links
- ❖ Bi-directional sync: ticket status → finding notes
- ❖ **“/ack”** commands to set workflow state
- ❖ Report **SLA breaches** automatically



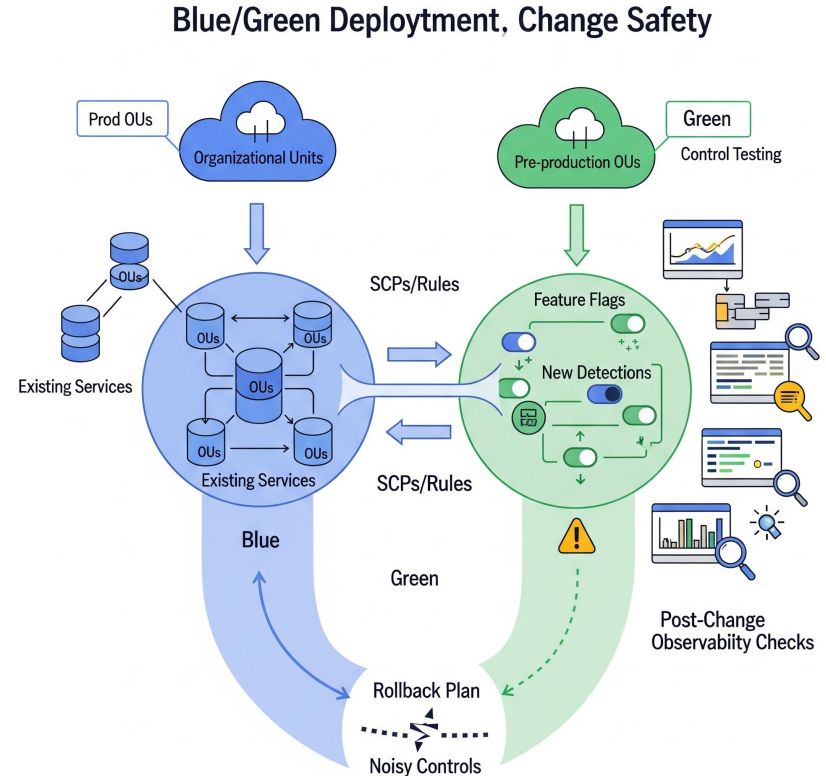
KPIs & Executive Reporting

- ❖ Open criticals, MTTR, repeat offenders
- ❖ Coverage of accounts/regions/tools
- ❖ Control compliance by **standard & OU**
- ❖ **Trend lines** and **burn-down** charts
- ❖ Tie to **risk register** & audits



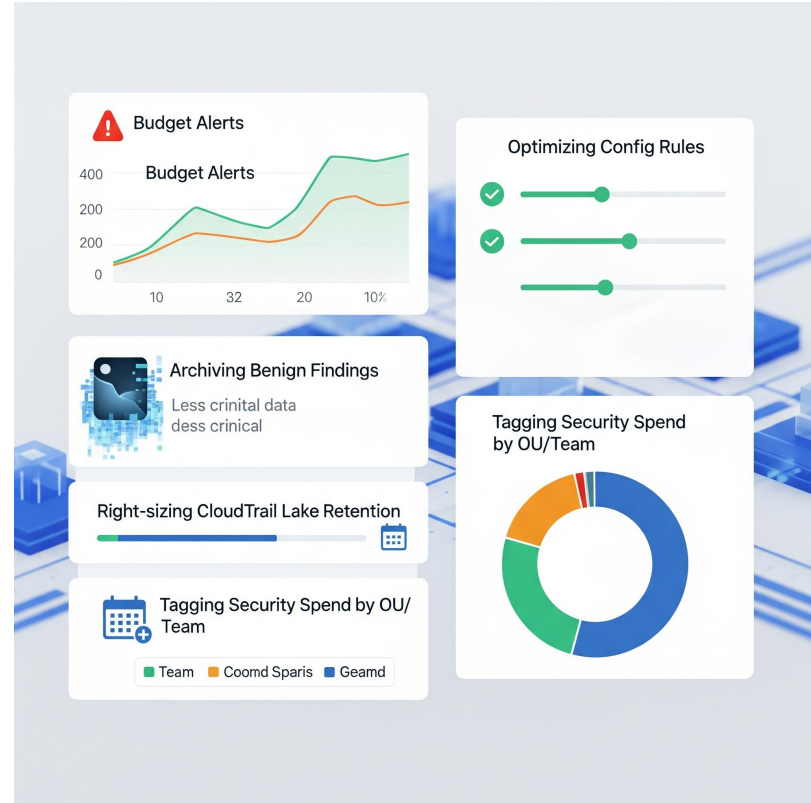
Blue/Green & Change Safety

- ❖ Use **pre-prod** OUs for control testing
- ❖ Progressive rollout of **SCPs/rules**
- ❖ **Feature flags** for new detections
- ❖ **Rollback** plans for noisy controls
- ❖ Post-change **observability checks**



Cost Governance for Security Tools

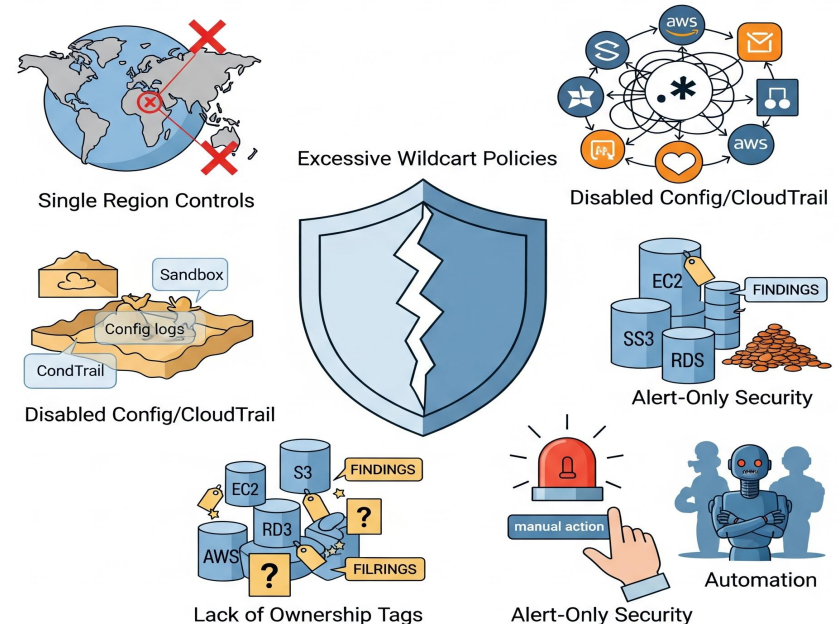
- ❖ Budget alerts for **Security Hub/Inspector/Macie**
- ❖ Optimize **Config rules** & evaluation frequency
- ❖ Archive benign findings to cut **volume**
- ❖ Right-size **CloudTrail Lake** retention
- ❖ Tag security spend by **OU/team**



Common Pitfalls & Anti-Patterns

- ❖ Relying on **single region** for controls
- ❖ Excessive * in policies & resource ARNs
- ❖ Disabling **Config/Trail** in sandbox accounts
- ❖ No **ownership tags** → untriaged findings
- ❖ “Alert-only” without **automation**

Common Pitfalls and Anti-Patterns in AWS Cloud Security



Final Checklist

- ❖ Org-wide
Hub/Trail/Config/GuardDuty
enabled
- ❖ **SCPs + permission boundaries**
implemented
- ❖ **Access Analyzer** clean for
public/external
- ❖ Automated **remediations** for top
issues



Summary

- Advance Security Features
- Security Hub Deep Dive:
- IAM Best Practices:
- AWS Config, CloudTrail, and GuardDuty
- End-to-End Telemetry and Reporting

Q&A and Next Steps



01 Ask questions and get answers now

03 Discuss future plans and actions

02 Connect for further information and support

04 Review key takeaways from the presentation